

A análise qualitativa de riscos	Processo que determina a probabilidade de ocorrência e o impacto dos riscos identificados usando o raciocínio lógico quando os dados numéricos não estão prontamente disponíveis.
A análise quantitativa de riscos	Método numérico que é usado para avaliar a probabilidade e o impacto do risco e medir o impacto.
access control list (lista de controle de acesso)	Conjunto de entradas de controle de acesso (ACEs) que determina quais elementos (contas de usuário, endereços IP de host e similares) têm o acesso permitido ou negado e privilégios concedidos em relação ao objeto (somente leitura, leitura/gravação, etc.).
Access point	Dispositivo que fornece uma conexão entre dispositivos sem fio e pode se conectar a redes com fio, implementando um modo de infraestrutura WLAN.
accounting (controle)	Monitora o uso autorizado de um recurso ou o uso de direitos por uma entidade e alerta quando é detectado ou tentado o uso não autorizado.
aceitação de riscos	A resposta de determinar que um risco está dentro do que é aceitável pela organização e que nenhuma contramedida além do monitoramento contínuo é necessária.
acesso remoto	Infraestrutura, protocolos e software que permitem que um host se junte a uma rede local a partir de uma localização física remota ou que permitem que uma sessão em um host seja estabelecida mediante uma rede.
Acesso Wi-Fi protegido	Padrões para autenticação e criptografia de acesso a redes Wi-Fi. Também chamado de WPA2 e WPA3.
adware	Software que registra informações sobre um computador e seu usuário. O termo é usado para descrever softwares capazes de registrar informações sobre os hábitos do usuário após obter o seu consentimento.
afinidade de sessão	Formato de agendamento usado pelos balanceadores de carga para rotear o tráfego para dispositivos que já estabeleceram conexões com o cliente em questão.
Agregação de logs	Analisar informações de várias fontes de dados de logs e eventos de segurança para poderem ser apresentadas em um formato consistente e pesquisável.
ajuste de alerta	Processo de ajustar as regras de detecção e correlação para reduzir a incidência de falsos-positivos e alertas de baixa prioridade.
algoritmo	Operações que transformam um texto simples em um texto cifrado com propriedades criptográficas, também chamadas de cifra. Existem cifras simétricas, assimétricas e hash.

algoritmo assimétrico	Cifra que usa chaves públicas e privadas. As chaves são vinculadas matematicamente usando o algoritmo Rivest–Shamir–Adleman (RSA) ou criptografia de curva elíptica (ECC), mas a chave privada não é derivável da pública. Uma chave assimétrica não pode reverter a operação que executa, de modo que a chave pública não pode descriptografar o que criptografou, por exemplo.
Algoritmo de digestão de mensagens v5	Uma função de hash criptográfica que produz uma saída de 128 bits.
Algoritmo hash seguro	Algoritmo hash criptográfico criado para resolver possíveis lacunas no MDA. A versão atual é SHA-2.
allow listing	Configuração de segurança em que o acesso é negado a qualquer entidade (processo de software, IP/domínio e assim por diante) a menos que conste na lista de permissões.
Alta disponibilidade	Métrica que define a proximidade dos sistemas em relação à meta de fornecer disponibilidade de dados 100% do tempo, mantendo um alto nível de desempenho do sistema.
ameaça	Possibilidade de uma entidade se aproveitar de uma vulnerabilidade (ou seja, violar a segurança).
ameaça intencional	Autor de ameaças com um propósito mal-intencionado.
ameaça interna	Tipo de autor de ameaça que recebe privilégios no sistema que causam um incidente intencional ou não.
ameaça interna não intencional	Autor de ameaças que causa uma vulnerabilidade ou expõe um vetor de ataque sem intenção criminosa.
ameaça persistente avançada	Atores de ameaças com a capacidade de criar novas explorações e técnicas para obter, manter e diversificar o acesso não autorizado a sistemas de rede por um longo período.
ameaça persistente avançada	A capacidade de um invasor de obter, manter e diversificar o acesso a sistemas de rede usando explorações e malware.
análise da causa raiz	Uma técnica usada para determinar a verdadeira causa do problema, que, quando removida, impede que ele ocorra novamente.
análise de comportamento de usuários e entidades	Um sistema que pode fornecer identificação automatizada de atividades suspeitas por contas de usuário e hosts de computador.
Análise de impacto nos negócios	Atividade sistemática que identifica os riscos organizacionais e determina seu efeito nas operações essenciais em curso.
análise de lacuna	Uma análise que mede a diferença entre os estados atual e desejado, a fim de ajudar a avaliar o escopo do trabalho incluído em um projeto.
análise de pacotes	Análise dos cabeçalhos e dados de payload de um ou mais quadros no tráfego de rede registrado.
análise de portas comutadas	Copiar comunicações recebidas e/ou emitidas de uma ou mais portas de switch para outra porta. Isto é usado para monitorar as comunicações que passam pelo switch. Veja também: Espelhamento de porta.
análise de riscos	Processo para qualificar ou quantificar a probabilidade e o impacto de um fator.

Análise de tendências	Processo de detectar padrões dentro de um conjunto de dados ao longo do tempo e usá-los para fazer previsões sobre eventos futuros ou para entender melhor eventos passados.
análise dinâmica	Teste de software que examina o comportamento do código durante o tempo de execução. Ajuda a identificar possíveis problemas de segurança, desempenho ou outros.
Análise do código estático	O processo de revisão do código-fonte não compilado, seja manualmente ou usando ferramentas automatizadas.
análise heurística	Método que usa comparações e análise da semelhança de recursos, em vez da equivalência de uma assinatura específica, para identificar se o objeto da observação é mal-intencionado.
antivírus	Inspeção do tráfego para localizar e bloquear vírus.
apetite ao risco	Uma avaliação estratégica sobre qual nível de risco residual é aceitável para uma organização.
aprendizado de máquina	Componente de IA que permite a uma máquina desenvolver estratégias para resolver uma tarefa dado um conjunto de dados rotulado em que os recursos foram identificados manualmente mas sem quaisquer outras instruções explícitas.
aquisição de dados	Na análise forense digital, trata-se do método e das ferramentas usados para criar uma cópia com validade forense dos dados de um dispositivo de origem, como disco rígido ou memória do sistema.
aquisição/obtenção	Políticas e processos que garantem que aquisições e contratos de ativos e serviços sejam totalmente gerenciados e protegidos, empreguem fornecedores/vendedores autorizados e atendam às metas de negócios.
ARP poisoning (envenenamento de ARP)	Ataque em que um invasor injeta registros de recursos falsos em um cache de cliente ou servidor para redirecionar um nome de domínio para um endereço IP da escolha do invasor.
arquitetura de computação centralizada	Modelo em que todo o processamento e armazenamento de dados é realizado em um único local.
Arquitetura de computação descentralizada	Modelo em que o processamento e armazenamento de dados são distribuídos em vários locais ou dispositivos.
arquiteturas multinuvem	Modelo de implantação em nuvem em que o consumidor da nuvem usa vários serviços de nuvem pública.
arquivo de dump file (dump file)	Um arquivo que contém dados capturados da memória do sistema.
As extensões de segurança do DNS (DNSSEC)	Protocolo de segurança que fornece autenticação de dados DNS e mantém a integridade dos dados DNS.
Assinatura de código	Método que usa uma assinatura digital para garantir a origem e integridade do código de programação.
assinatura digital	Um resumo de mensagem criptografado usando a chave privada do remetente que é anexada a uma mensagem para autenticar o remetente e provar a integridade da mensagem.

ataque a aplicativos	Ataque direcionado contra uma vulnerabilidade de codificação, implementação ou plataforma no sistema operacional ou software de aplicativo.
ataque à cadeia de suprimentos	Um ataque que tem como alvo o processo de ponta a ponta de fabricação, distribuição e manuseio de bens e serviços.
ataque à rede	Ataque direcionado contra uma infraestrutura de rede cabeada e/ou wireless, incluindo táticas como reconhecimento, negação de serviço, coleta de credenciais, on-path, escalção de privilégios e exfiltração de dados.
ataque ambiental	Ameaça física direcionada contra sistemas de energia, resfriamento ou supressão de incêndio.
ataque birthday	Tipo de ataque de senha que explora fraquezas nos algoritmos matemáticos usados para criptografar senhas, a fim de aproveitar a probabilidade de diferentes entradas de senha produzirem a mesma saída criptografada.
ataque de amplificação	Ataque baseado em rede no qual o invasor aumenta drasticamente a largura de banda enviada a uma vítima durante um ataque DDoS, implementando um fator de amplificação.
ataque de canonicalization (canonização)	Método de ataque em que os caracteres de entrada são codificados de forma a evadir medidas de validação de entrada vulneráveis.
ataque de colisão	Em criptografia, o ato de duas entradas de texto simples diferentes produzirem a mesma saída de texto cifrado.
ataque de dicionário	Tipo de ataque de senha que compara senhas criptografadas com uma lista predeterminada de possíveis valores de senha.
ataque de downgrade	Um ataque criptográfico em que o invasor explora a necessidade de compatibilidade com versões anteriores para forçar um sistema de computador a abandonar o uso de mensagens criptografadas em favor de mensagens de texto simples.
ataque de falsificação	Ataque que explora a autenticação fraca para executar uma solicitação durante a sessão invadida.
ataque de força bruta	Tipo de ataque de senha em que um invasor usa um aplicativo para tentar exaustivamente todas as combinações alfanuméricas possíveis para quebrar senhas criptografadas.
ataque de injeção	Ataque que explora fraquezas no tratamento de solicitações ou na validação de entradas para executar um código arbitrário em um navegador do cliente ou em um servidor.
Ataque de negação de serviço	Qualquer tipo de ataque físico, de aplicativo ou de rede que afete a disponibilidade de um recurso gerenciado.
ataque de senha	Qualquer ataque em que o invasor tente obter acesso não autorizado e usar senhas.
ataque de senha híbrida	Ataque que usa métodos variados, incluindo ataques de dicionário, tabela arco-íris e força bruta, para tentar decifrar uma senha.
ataque distribuído de negação de serviço	Um ataque que usa vários hosts comprometidos (uma botnet) para sobrecarregar um serviço com tráfego de respostas ou solicitações.

ataque físico	Ataque a infraestrutura de cabeamento, dispositivos de hardware ou ambiente das instalações que hospedam uma rede.
ataque on-path	Ataque em que o autor da ameaça faz uma conexão independente entre duas vítimas e é capaz de ler e possivelmente modificar o tráfego.
ataque watering hole	Um ataque dirigido a grupos ou organizações específicas, no qual um invasor descobre quais sites o alvo frequenta e injeta código malicioso nesses sites.
atestação	Capacidade de um autenticador ou outro módulo criptográfico provar que é autoridade credível e pode fornecer relatórios confiáveis para provar que um dispositivo ou computador é uma plataforma confiável.
Ator de estado-nação	Um tipo de ator de ameaça que tem o suporte de recursos dos serviços militares e de segurança do país host.
atribuição/contabilização	Em gestão de ativos, processos que garantem que cada ativo físico e de dados tenha um proprietário identificado e seja adequadamente rotulado e classificado em um inventário.
atualização mal-intencionada	Vulnerabilidade no repositório de software ou na cadeia de suprimentos que um invasor pode explorar para adicionar código malicioso a um pacote.
auditoria de sistema/processo	Processo de auditoria com amplo escopo, incluindo avaliação da cadeia de suprimentos, configuração, suporte, monitoramento e fatores de segurança cibernética.
autenticação biométrica	Mecanismo de autenticação que permite ao usuário realizar uma varredura biométrica para operar um sistema de entrada ou acesso. Características físicas armazenadas como um modelo de dados digitais podem ser usadas para autenticar um usuário. Os recursos típicos usados incluem padrão facial, íris, retina, padrão de impressão digital e reconhecimento de assinatura.
Autenticação do NT LAN Manager	Protocolo de autenticação tipo desafio-resposta criado pela Microsoft para uso em seus produtos.
Autenticação simultânea de iguais	Mecanismo de autenticação pessoal para redes Wi-Fi introduzido com o WPA3 para solucionar vulnerabilidades no método WPA-PSK.
autenticação, autorização e contabilização	Conceito de segurança em que uma plataforma centralizada verifica a identificação do sujeito, garante que ele receba permissões adequadas e, em seguida, registra essas ações para criar uma trilha de auditoria.
Autenticação, relatório e conformidade de mensagens baseadas em domínio	Estrutura para garantir a aplicação adequada de SPF e DKIM usando uma política publicada como registro DNS.
autenticador	Switch ou roteador PNAC que ativa o EAPoL e passa os dados de autenticação de um solicitante a um servidor de autenticação, como um servidor RADIUS.
authentication (autenticação)	Método para validar as credenciais exclusivas de uma entidade ou indivíduo em particular.

autoridade certificadora	Em PKI, uma CA que emite certificados para CAs intermediárias em uma estrutura hierárquica.
Autoridade certificadora	Um servidor que garante as identidades dos sujeitos emitindo invólucros de certificados digitais assinados para suas chaves públicas.
autoridade certificadora terceirizada	Em uma PKI, refere-se a uma autoridade de certificação pública que emite certificados para múltiplos domínios e é amplamente aceita como autoridade credível por sistemas operacionais e navegadores.
autorização	O processo de determinar quais direitos e privilégios uma entidade em particular possui.
Autorização aberta	Um padrão para gerenciamento de identidade federada, permitindo que servidores de recursos ou sites de consumidores funcionem com contas de usuário criadas e gerenciadas em um provedor de identidade separado.
autorizado	Um hacker envolvido em testes de penetração autorizados ou outra consultoria de segurança.
availability (disponibilidade)	A meta fundamental da segurança, de garantir que os sistemas operem continuamente e que indivíduos autorizados possam acessar os dados de que precisam.
avaliação de risk (risco)	Processo de identificar riscos, analisá-los, desenvolver uma estratégia de resposta a eles e mitigar seu impacto futuro.

B

backdoor	Mecanismo para acesso a um computador que ignora ou subverte o método normal de autenticação.
backup	Uma cópia de segurança dos dados de produção feita em mídia removível, normalmente de acordo com um cronograma regular. Diferentes tipos de backup (completo, incremental ou diferencial) equilibram a capacidade da mídia, o tempo exigido para efetuar o backup e o tempo exigido para restaurar.
backup externo	O backup que grava os dados do trabalho em uma mídia armazenada em um local físico separado do sistema de produção.
backups locais	Backup que grava os dados do trabalho em uma mídia que é armazenada no mesmo local físico do sistema de produção.
balanceador de carga	Um tipo de switch, roteador ou software que distribui solicitações de clientes entre diferentes recursos, como links de comunicação ou servidores configurados de forma semelhante. Isso proporciona tolerância a falhas e melhora a taxa de transferência.
blockchain	Conceito segundo o qual uma crescente lista de registros transacionais registrados em um livro-razão público é protegida usando criptografia.
bloqueador de gravação	Uma ferramenta forense para impedir que o dispositivo de captura ou análise ou a estação de trabalho altere dados em um disco ou mídia de destino.
bloqueio de conta	Política que impede o acesso a uma conta sob certas condições, como um número excessivo de tentativas de autenticação malsucedidas.
bluejacking	Envio de uma mensagem ou imagem não solicitada usando uma conexão Bluetooth.

bluesnarfing	Um ataque wireless em que um invasor obtém acesso a informações não autorizadas em um dispositivo usando uma conexão Bluetooth.
Bluetooth	Meio de transmissão de rede sem fio e de curto alcance por rádio normalmente usado para conectar dois dispositivos pessoais, como um telefone celular e um headset wireless.
bollards	Poste vertical robusto instalado para controlar o tráfego rodoviário ou projetado para evitar ataques em que um veículo é utilizado como arma.
bomba lógica).	Programa ou script mal-intencionado configurado para ser executado em circunstâncias específicas ou em resposta a um evento definido.
botnet	Grupo de hosts ou dispositivos que foram infectados por um programa de controle chamado bot, o qual permite que os invasores explorem os hosts para montar ataques. Também chamado de zumbi.
buffer overflow (transbordamento de buffer)	Ataque no qual os dados ultrapassam o limite do buffer destinatário e começam a corromper a memória adjacente. Isso pode permitir que o invasor trave o sistema ou execute um código arbitrário.
Busca de ameaças	Uma técnica de cibersegurança projetada para detectar a presença de ameaças que não foram descobertas pelo monitoramento de segurança normal.

C

cabeçalho de autenticação	Protocolo IPSec que fornece autenticação para a origem dos dados transmitidos, bem como integridade e proteção contra replay attacks.
cabeçalho de Internet	Registro dos servidores de email envolvidos na transferência de uma mensagem de email de um remetente para um destinatário.
cadeia de custódia	Registro do histórico de evidências, desde a coleta e apresentação no tribunal até o descarte.
camuflagem industrial	Métodos para disfarçar a natureza e a finalidade de edifícios ou partes de edifícios.
canal secreto	Tipo de ataque que subverte políticas e sistemas de segurança de rede para transferir dados sem autorização ou detecção.
celular	Os padrões para implementar o acesso a dados através de redes móveis são implementados como gerações sucessivas. Para 2G (até cerca de 48 Kb/s) e 3G (até cerca de 42 Mb/s), existem redes de provedores GSM e CDMA concorrentes. Os padrões para 4G (até cerca de 90 Mb/s) e 5G (até cerca de 300 Mb/s) são desenvolvidos sob padrões LTE convergentes.
Centro de Compartilhamento e Análise de Informações	Um grupo sem fins lucrativos criado para compartilhar práticas recomendadas de inteligência e segurança contra ameaças específicas do setor entre seus membros.
centro de distribuição de chaves	Componente do Kerberos que autentica usuários e emite tíquetes (tokens).
centro de operações de segurança	O local em que profissionais de segurança monitoram e protegem ativos de informações críticas em uma organização.
cercas	Barreira de segurança para impedir o acesso não autorizado a um perímetro do local.

certificação (descarte)	Técnica de descarte de ativos que depende de terceiros para usar métodos de higienização ou destruição visando a remoção de restos de dados. Ela fornece evidências documentais da conclusão e êxito do processo.
certificado autoassinado	Um certificado digital que foi assinado pela entidade que o emitiu, e não por uma CA.
certificado digital	Informações de identificação e autenticação apresentadas no formato X.509 e emitidas por uma autoridade de certificação (CA) como garantia de que um par de chaves (conforme identificado pela chave pública incorporada no certificado) é válido para uma entidade específica (usuário ou host).
chantagem	Exigir pagamento para evitar a divulgação de informações.
chave	Em criptografia, trata-se de uma informação específica que é usada com um algoritmo para executar a criptografia e descriptografia.
chave de criptografia	Na criptografia de armazenamento, a chave privada que é usada para criptografar a chave simétrica de criptografia de mídia em massa (MEK). Isso significa que um usuário deve se autenticar para descriptografar a MEK e acessar a mídia.
chave de segurança	HSM portátil com uma interface de computador, como USB ou NFC, usado para autenticação multifator.
chave pré-compartilhada	Modo de autenticação de rede sem fio em que um mecanismo baseado em senha é usado para permitir autenticação de grupo em uma rede sem fio. A frase de acesso é usada para originar uma chave de criptografia.
chave privada	Na criptografia assimétrica, a chave privada é conhecida apenas pelo titular e está vinculada a uma chave pública (mas não deriva dela) distribuída àqueles com os quais o titular deseja se comunicar com segurança. Uma chave privada pode ser usada para criptografar dados que podem ser descriptografados pela chave pública vinculada ou vice-versa.
chave pública	Durante a criptografia assimétrica, essa chave é distribuída livremente e é usada para criptografar dados, que só podem ser descriptografados pela chave privada vinculada no par.
ciclo de vida de desenvolvimento de software	Processos de planejamento, análise, projeto, implementação e manutenção que geralmente regem o desenvolvimento de software e sistemas.
classificações de dados	Processo de aplicação de rótulos de confidencialidade e privacidade às informações.
clonagem de crachá	Fazer uma cópia de um crachá de acesso sem contato.
cloud computing (computação em nuvem)	Arquitetura de computação em que os recursos sob demanda provisionados que possuem atributos de alta disponibilidade, escalabilidade e elasticidade são cobrados dos clientes com base no uso medido.
clustering (agregação)	Técnica de balanceamento de carga em que um grupo de servidores é configurado como uma unidade e trabalha para fornecer serviços de rede.
Codificação por cento	Mecanismo para codificar caracteres como valores hexadecimais delimitados pelo sinal de porcentagem.

código de autenticação de mensagem baseado em hash	Método usado para verificar a integridade e autenticidade de uma mensagem combinando um hash criptográfico da mensagem com uma chave secreta.
código de conduta,	O comportamento profissional depende de padrões éticos básicos, como honestidade e equidade. Algumas profissões desenvolvem códigos de ética para abranger situações difíceis; algumas empresas também podem ter um código de ética para comunicar os valores que esperam que seus funcionários pratiquem.
coleta de credenciais	Técnicas de engenharia social para reunir credenciais válidas para obter acesso não autorizado.
com folga de ar	Tipo de isolamento de rede que separa fisicamente um host de outros ou uma rede de todas as outras.
comando chmod	Comando Linux para gerenciar permissões de arquivos.
comando dd	Comando Linux que faz uma cópia bit por bit do arquivo apresentado, normalmente usado para gerar imagens de disco.
Comando e controle	Infraestrutura de hosts e serviços com os quais os invasores direcionam, distribuem e controlam malware em botnets.
comitê de governança	Líderes e especialistas do ramo que são responsáveis por definir políticas, procedimentos e padrões de um domínio ou escopo específico.
community cloud (nuvem comunitária)	Nuvem que é implantada para uso compartilhado por locatários em cooperação.
comprometimento de email comercial	Ataque de personificação no qual o invasor assume o controle da conta de um funcionário e a usa para convencer outros funcionários a realizar ações fraudulentas.
computação	Recursos de processamento, memória, armazenamento e rede que permitem a um host ou dispositivo de rede lidar com determinada carga de trabalho.
computação de rede virtual	Ferramenta e protocolo de acesso remoto. VNC é a base do compartilhamento de tela do macOS.
computação sem servidor	Recursos e funcionalidades de um servidor sem a necessidade de executar tarefas de administração do servidor. A computação serverless transfere o gerenciamento de infraestrutura para o provedor de serviços em nuvem, por exemplo, configurando a capacidade de armazenamento de arquivos sem a necessidade de primeiro criar e implantar um servidor de arquivos.
comunicação de campo próximo	Um padrão para comunicações de rádio bidirecionais em distâncias muito curtas (cerca de dez centímetros), facilitando o pagamento sem contato e tecnologias semelhantes. O NFC é baseado em RFID.
concessão de bilhetes	No Kerberos, um token emitido para uma conta autenticada para permitir o acesso a servidores de aplicativos autorizados.
condição de corrida	Vulnerabilidade de software que se dá quando o resultado dos processos de execução depende diretamente da ordem e do tempo de certos eventos, os quais não são executados na ordem e no tempo pretendidos pelo desenvolvedor.
confiança zero	Paradigma de design de segurança em que qualquer solicitação (entre hosts ou entre contêineres) deve ser autenticada antes de ser permitida.

confidentiality (confidencialidade)	A meta fundamental da segurança, de manter as informações e comunicações privadas e protegê-las contra acesso não autorizado.
Configuração Wi-Fi protegida	Um recurso do WPA e do WPA2 que permite o registro em uma rede wireless com base em um PIN de oito dígitos.
configurações padrão	Em uma arquitetura IaC, a propriedade de que uma ação de automação ou orquestração sempre produz o mesmo resultado, independentemente do estado anterior do componente.
configuration baseline (linha de base de configuração)	Definições de serviços e configurações de política para um dispositivo de rede ou para um servidor que opera em uma função de aplicativo específica (servidor Web, servidor de email, servidor de impressão/servidor de arquivos e assim por diante).
conflito de interesses	Quando um indivíduo ou organização tem investimentos ou obrigações que podem comprometer sua capacidade de agir de forma objetiva, imparcial ou no melhor interesse de outra parte.
conjunto de cifras	Listas de algoritmos criptográficos que um servidor e um cliente podem usar para negociar uma conexão segura.
conselhos de governança	Executivos seniores e intervenientes externos com responsabilidade de definir a estratégia e garantir a conformidade.
consumo de recursos	Um possível indício de atividades mal-intencionadas em que o uso da CPU, memória, armazenamento e/ou rede se desvia das normas esperadas.
conta de grupo de segurança	Coleção de contas de usuários que pode ser útil ao estabelecer permissões de arquivos e direitos de usuários, porque quando muitos indivíduos precisam do mesmo nível de acesso, permite estabelecer um grupo contendo todos os usuários relevantes.
containerização	Uma implantação de virtualização do sistema operacional contendo tudo o que é necessário para executar um serviço, aplicativo ou microsserviço.
Continuidade das operações	Identifica como os processos de negócios devem lidar tanto com interrupções menores como catastróficas, garantindo que haja redundância de processamento que suporte o fluxo de trabalho.
contrato de nível de serviço	Acordo que define os requisitos e as expectativas de serviço entre um consumidor e um provedor.
contrato de parceria comercial	Acordo entre duas empresas para trabalhar em conjunto, como os acordos de parceria que grandes empresas de TI estabelecem com revendedores e provedores de soluções.
contrato de serviço principal	Um contrato que estabelece precedência e diretrizes para quaisquer documentos comerciais executados entre duas partes.
controlador de dados	Nos regulamentos de privacidade, a entidade que determina por que e como os dados pessoais são coletados, armazenados e usados.
controle compensatório	Uma medida de segurança que assume a mitigação de riscos quando um controle primário falha ou não consegue atender completamente às expectativas.
controle corretivo	Um tipo de controle de segurança que atua após um incidente para eliminar ou minimizar seu impacto.

controle de acesso baseado em atributos	Técnica de controle de acesso que avalia um conjunto dos atributos de cada sujeito para determinar se o acesso deve lhe ser concedido.
Controle de acesso baseado em função	Modelo de controle de acesso em que os recursos são protegidos por ACLs gerenciadas por administradores e fornecem permissões de usuário com base em funções de trabalho.
controle de acesso baseado em regras	Técnica de controle de acesso não discricionário baseada em um conjunto de regras ou restrições operacionais para impor uma política de permissões de privilégios mínimos.
Controle de acesso discricionário	Modelo de controle de acesso em que cada recurso é protegido por uma lista de controle de acesso (ACL) gerenciada pelo proprietário (ou proprietários) do recurso.
Controle de acesso obrigatório	Um modelo de controle de acesso em que os recursos são protegidos por regras inflexíveis definidas pelo sistema. Recursos (objetos) e usuários (indivíduos) recebem um nível de autorização (ou rótulo).
controle de dissuasão	Um tipo de controle de segurança que desencoraja tentativas de intrusão.
controle de mudanças	Processo pelo qual a necessidade de mudança é registrada e aprovada.
controle de segurança	Tecnologia ou procedimento implementado para mitigar vulnerabilidades e riscos e garantir a confidencialidade, integridade e disponibilidade (confidentiality, Integrity, Availability — CIA) das informações.
controle de segurança ativo	Controles de segurança detectivos e preventivos que usam um agente ou configuração de rede para monitorar hosts. Isso permite uma varredura credenciada mais precisa, mas consome alguns recursos do host e é detectável por invasores.
controle de segurança passivo	Varredura de enumeração, vulnerabilidades ou detecção de incidentes que analisa apenas o tráfego de rede interceptado, em vez de enviar sondas a um alvo. De modo mais geral, as técnicas de reconhecimento passivo são aquelas que não requerem interação direta com o alvo.
Controle de supervisão e aquisição de dados	Tipo de sistema de controle industrial que gerencia dispositivos e equipamentos de múltiplos locais, em larga escala, espalhados por áreas geograficamente grandes a partir de um computador host.
controle de versão	Prática de garantir que os ativos que compõem um projeto sejam gerenciados detalhadamente quando é necessário fazer alterações. Também conhecido como controle de origem.
controle detectivo	Tipo de controle de segurança que atua durante um incidente para identificar ou registrar os acontecimentos.
controle diretivo	Tipo de controle que impõe uma regra de comportamento por meio de uma política ou contrato.
controle físico	Categoria de controle de segurança que atua contra tentativas de intrusão presencial.
controle gerencial	Uma categoria de controle de segurança que supervisiona o sistema de informação.

Controle M-de-N	Um meio de limitar o acesso a chaves de criptografia essenciais, como a chave privada de uma CA raiz. Pelo menos M do número total (N) de indivíduos autorizados deve estar presente para acessar a chave.
controle preventivo	Tipo de controle de segurança que atua antes de um incidente para eliminar ou reduzir a probabilidade de sucesso de um ataque.
controle técnico	Categoria de controle de segurança que é implementada como um sistema (hardware, software ou firmware). Os controles técnicos também podem ser descritos como controles lógicos.
Controles operacionais	Categoria de controle de segurança que é implementado por pessoas.
convenção de nomenclatura padrão	Aplicação de nomes e rótulos consistentes a ativos e recursos/identidades digitais dentro de um sistema de gerenciamento de configuração.
cookie	Arquivo de texto usado para armazenar informações sobre um usuário quando ele visita um site. Alguns sites usam cookies para oferecer suporte às sessões do usuário.
correlação	Uma função da análise de log que vincula logs e dados de estado para identificar um padrão que deve ser registrado ou alertado como um evento.
corretor de segurança de acesso à nuvem	Software de gestão corporativa projetado para mediar o acesso de usuários a serviços em nuvem em todos os tipos de dispositivos.
credential replay attacks (ataques de repetição de credenciais).	Ataque que usa um token de autenticação capturado para iniciar uma sessão não autorizada sem ter que descobrir a senha em texto simples de uma conta.
Criação de scripts entre sites	Um script mal-intencionado hospedado no site do invasor ou codificado em um link injetado em um site confiável com a intenção de comprometer seus usuários, contornando o modelo de segurança de zonas confiáveis do navegador.
Crime organizado	Um tipo de ator de ameaça que usa hacking e fraude de computador para ganho comercial.
criptoanálise	Ciência, arte e prática de decifrar códigos e cifras.
criptografia	Ciência e prática de alterar dados visando torná-los ininteligíveis às partes não autorizadas.
criptografia (criptografia)	Embaralhar os caracteres usados em uma mensagem para que ela possa ser visualizada, mas não entendida ou modificada, a menos que possa ser decifrada. A criptografia é um meio seguro de transmissão de dados e autenticação de usuários. Também é usado para armazenar dados com segurança. A criptografia usa diferentes tipos de cifras e uma ou mais chaves. O tamanho da chave é um fator que determina a força do resultado da criptografia.
CRIPTOGRAFIA COMPLETA DO DISCO	A criptografia de todos os dados em um disco (incluindo arquivos do sistema, arquivos temporários e o arquivo de paginação) pode ser realizada por meio de um sistema operacional compatível, um software de terceiros ou ao nível do controlador pelo próprio dispositivo de disco.

criptografia de banco de dados	Aplicação de criptografia no âmbito da tabela, do campo ou do registro por meio de um sistema de gerenciamento de banco de dados, e não do sistema de arquivos.
Criptografia de transporte/comunicação	Esquema de criptografia aplicado a dados em movimento, como WPA, IPsec ou TLS.
criptografia simétrica	Esquema de criptografia bidirecional no qual a criptografia e a descriptografia são executadas pela mesma chave. Também conhecido como criptografia de chave compartilhada.
criptominer	Malware que assume o controle dos recursos do computador para criar criptomoedas.
custodiante de dados	Indivíduo responsável por gerenciar o sistema no qual os ativos de dados são armazenados, bem como impor medidas de controle de acesso, criptografia e backup/recuperação.

D

da CompTIA	Procedimentos e diretrizes que abrangem prioridades, ações e responsabilidades apropriadas em caso de incidentes de segurança, divididos em etapas de preparação, detecção, análise, contenção, erradicação/recuperação e lições aprendidas.
Dados de log	O software do sistema operacional e dos aplicativos pode ser configurado para registrar eventos em log automaticamente. Isso fornece informações valiosas de solução de problemas. Os logs de segurança fornecem uma trilha de auditoria das ações realizadas no sistema, bem como avisos de atividades suspeitas. É importante que a configuração do registro de log e os arquivos sejam tornados invioláveis.
dados de telemetria falsos	Estratégia de engano que retorna dados falsificados em resposta a sondagens de rede.
dados em movimento	Informações transmitidas entre dois hosts por uma rede privada ou pela Internet, por exemplo.
dados em processamento	Informações presentes na memória volátil de um host, como memória ou cache do sistema.
dados em repouso	Informações que são armazenadas primordialmente em mídias específicas, em vez de serem movidas de uma mídia para outra.
dados em trânsito	Informações transmitidas entre dois hosts por uma rede privada ou pela Internet, por exemplo. Também chamado de "dados em movimento".
Dados em uso	Informações presentes na memória volátil de um host, como memória ou cache do sistema.
Dados legais	Documentos e registros relacionados a assuntos jurídicos, como contratos, propriedade, casos em juízo e registros regulatórios.
dados legíveis por humanos	Informações armazenadas em um tipo de arquivo que humanos podem acessar e entender usando um software básico de visualização, como documentos, imagens, vídeo e áudio.

dados não legíveis por humanos	Informações armazenadas em um arquivo não legível por humanos sem um processador especializado para decodificar a estrutura binária ou complexa.
dados regulamentados	Informações que possuem requisitos de conformidade para armazenamento e manuseio definidos pela legislação nacional e estadual e/ou regulamentações do setor.
Dark web	Recursos da Internet que são distribuídos entre nós anônimos e protegidos do acesso geral por várias camadas de criptografia e roteamento.
Data historian (historiador de dados)	Software que agrega e cataloga dados de várias fontes dentro de um sistema de controle industrial.
data sovereignty (soberania de dados)	Em proteção de dados, o princípio de que países e estados podem impor requisitos individuais aos dados coletados ou armazenados dentro de sua jurisdição.
deauthentication/disassociation attack (ataque de desautenticação/desassociação)	Falsificação de quadros que visa desconectar uma estação wireless e tentar obter dados de autenticação para decifrá-los.
declaração de trabalho	Documento que define as expectativas para um acordo comercial específico.
defesa aprofundada	Estratégia de segurança que posiciona camadas de diversas categorias e funções de controle de segurança ao invés de basear-se apenas em controles de perímetro.
dependências	Recursos e outros serviços que devem estar disponíveis e em execução para que um serviço seja iniciado.
descarte/desativação	Em gestão de ativos, as políticas e os procedimentos que regem a remoção de dispositivos e software das redes de produção e seu posterior descarte por meio de venda, doação ou como resíduo.
Desenvolvimento e operações (DevOps)	Combinação de desenvolvimento de software e operações de sistemas. Refere-se à prática de integrar uma disciplina à outra.
desinformação	Tipo de ataque que falsifica um recurso de informação em que outros normalmente confiam.
desprovisionamento	Processo de remoção de uma conta, host ou aplicativo do ambiente de produção. Isso requer a revogação de qualquer acesso privilegiado que tenha sido atribuído ao objeto.
Destruição	Técnica de descarte de ativos que garante que os resíduos de dados se tornem fisicamente inacessíveis e irrevogáveis por meio de desmagnetização, trituração ou incineração.
detecção	Processo de resposta a incidentes que correlaciona dados de eventos para determinar se são indicadores de um incidente.

detecção baseada em assinatura	Sistema de monitoramento de rede que usa um conjunto predefinido de regras concedido por um fornecedor de software ou pessoal de segurança para identificar eventos inaceitáveis.
Detecção baseada em comportamento	Sistema de monitoramento de rede que detecta alterações nas sequências de dados operacionais normais e identifica sequências anormais.
detecção de anomalias no comportamento da rede	Ferramenta de segurança que monitora comportamentos anômalos em pacotes de rede com base em assinaturas conhecidas.
detecção e resposta de endpoints	Agente de software que coleta dados e logs do sistema para que um sistema de monitoramento os analise e forneça detecção precoce de ameaças.
devido processo	Termo usado no direito comum dos EUA e do Reino Unido para exigir que as pessoas só sejam condenadas por crimes após a aplicação justa das leis do país.
DevSecOps	Uma combinação de desenvolvimento de software, operações de segurança e operações de sistemas, e refere-se à prática de integrar cada disciplina com as outras.
dia zero	Vulnerabilidade em software ainda não é corrigida pelo desenvolvedor ou um ataque que explora essa vulnerabilidade.
Diffie-Hellman	Uma técnica criptográfica que proporciona a troca segura de chaves.
diligência prévia	Um princípio legal de que um sujeito usou as práticas recomendadas ou cuidados razoáveis ao configurar e manter um sistema.
diretor de informações	Um diretor da empresa que tem como responsabilidade principal a gestão de ativos e procedimentos da tecnologia da informação.
Diretor de Segurança da Informação	Normalmente, o cargo da pessoa com responsabilidade geral pela garantia de informações e segurança dos sistemas.
Diretor de Tecnologia	Um diretor da empresa com o papel principal de fazer uso efetivo de plataformas e inovações de computação novas e emergentes.
diretrizes	Recomendações de boas práticas e conselhos para itens de configuração em que políticas e padrões detalhados e estritamente aplicáveis são impraticáveis.
dispersão geográfica	Mecanismo de resiliência em que os recursos de processamento e armazenamento de dados são replicados entre locais fisicamente distantes.
dissuasão de risco	Em mitigação de riscos, a resposta através da implantação de controles de segurança para reduzir a probabilidade e/ou o impacto de um cenário de ameaça.
distinguished name (nome distinto)	Uma coleção de atributos que definem um identificador exclusivo para qualquer recurso determinado em um diretório semelhante ao X.500.

Diversidade de plataformas	Estratégia de resiliência de segurança cibernética que aumenta os custos de um ataque provisionando vários tipos de controles, tecnologias, fornecedores e implementações criptográficas.
dívida técnica	Os custos decorrentes de manter-se um sistema ou produto ineficaz, em vez de substituí-lo por um mais bem projetado.
DomainKeys Identified Mail	Um mecanismo de autenticação criptográfica para email que usa uma public key (chave pública) publicada como um registro DNS.
domínio curinga	Em PKI, trata-se de um certificado digital que corresponderá a vários subdomínios de um domínio principal.
DoS refletido distribuído (DRDoS)	Uma solicitação mal-intencionada a um servidor legítimo é criada e enviada como link para a vítima, de modo que uma falha no servidor faça com que o componente mal-intencionado seja executado no navegador do alvo.

E

e-discovery	Procedimentos e ferramentas para coletar, preservar e analisar evidências digitais.
EAP sobre a rede de área local	Mecanismo de controle de acesso à rede baseado em portas (PNAC) que permite o uso da autenticação EAP quando um host se conecta a um switch Ethernet.
efêmeras	Em criptografia, trata-se de uma chave que é usada apenas no contexto de uma única sessão.
em linha	Inserção e configuração de um controle de segurança de rede para que ele se torne parte do caminho do cabo.
em uma lista de chamadas.	Um documento que lista contatos autorizados para notificação e colaboração durante um incidente de segurança.
embedded system (sistema integrado)	Um sistema eletrônico desenvolvido para executar uma função específica, dedicada, como um microcontrolador em um gotejamento médico ou componentes em um sistema de controle que gerencia uma planta de tratamento de água.
encadeamento de certificados	Método para validar um certificado rastreando cada CA que o assina, acompanhando a hierarquia até chegar à autoridade de certificação root. Também chamado de cadeia de confiança.
Encapsulamento de carga útil de segurança	Subprotocolo IPSec que permite a criptografia e autenticação do cabeçalho e do payload de um pacote de dados.
enclave seguro	Extensões de CPU que protegem os dados armazenados na memória do sistema para que um processo não confiável não possa lê-los.

endurecimento	Processo que confere proteção a uma configuração de host ou aplicativo reduzindo a superfície de ataque por meio de execuções restritas aos serviços necessários, instalação de software de monitoramento para proteção contra malware e intrusões e estabelecimento de um cronograma de manutenção para garantir que o sistema contenha atualizações atuais de segurança para estar seguro contra explorações de software.
engano e interrupção	Ferramentas e técnicas de resiliência de segurança cibernética para aumentar o custo de planejamento de um ataque para o autor da ameaça.
enterprise authentication (autenticação empresarial)	Modo de autenticação de rede wireless no qual o ponto de acesso atua como passagem para credenciais verificadas por um servidor AAA.
entrada de controle de acesso	Um sistema de entrada segura com dois gateways, dos quais apenas um está aberto a qualquer dado momento.
entropia	Uma medida de desordem. Os sistemas criptográficos devem exibir alta entropia para resistir melhor aos ataques de força bruta.
Envenenamento de ARP (ARP poisoning)	Um ataque baseado em rede no qual um invasor com acesso ao segmento-alvo da rede local redireciona um endereço IP ao endereço MAC de um computador que não é o destinatário pretendido. Pode ser usado para executar uma variedade de ataques, incluindo DoS, falsificação (spoofing) e on-path (anteriormente conhecido como man-in-the-middle).
equipe de resposta a incidentes de computador	Equipe responsável pela resposta a incidentes. O CIRT deve ter experiência em vários domínios de negócios (TI, RH, jurídico e marketing, por exemplo).
escalação de privilégios	A prática de explorar falhas em um sistema operacional ou outro aplicativo para obter um nível de acesso maior que o destinado ao usuário ou aplicativo.
escalação de privilégios horizontal	Quando um usuário acessa ou modifica recursos específicos aos quais não tem direito.
escalação de privilégios vertical	Caso em que um invasor pode executar funções que normalmente são atribuídas a usuários em posições mais elevadas e, muitas vezes, negadas explicitamente ao invasor.
escalonamento	No contexto de procedimentos de suporte, resposta a incidentes e relatórios de violações, o escalonamento é o processo de envolvimento de especialistas e funcionários seniores para auxiliar no gerenciamento de problemas.
escolha seu próprio dispositivo	Modelo de provisionamento de dispositivos móveis corporativos no qual os funcionários dispõem de uma seleção de aparelhos corporativos para trabalho e, opcionalmente, para uso privado.
escrow	No gerenciamento de chaves, o armazenamento de uma chave de backup com um terceiro.
esteganografia	Técnica para ocultar a existência de uma mensagem, geralmente incorporando informações em um arquivo ou outra entidade.

Estrutura da política do remetente	Um registro DNS que identifica hosts autorizados a enviar emails para o domínio.
Estrutura de cibersegurança	Padrões, práticas recomendadas e diretrizes para a gestão eficaz de riscos à segurança. Alguns frameworks são de natureza geral, enquanto outros são específicos para certos tipos de indústria ou tecnologia.
evil twin (gêmeo malévolo)	Um ponto de acesso sem fio que leva o usuário a acreditar que se trata de um ponto de acesso de rede legítimo.
exceção de risco	Categoria de gestão de riscos que usa controles de mitigação alternados para administrar um fator de risco aceito.
exceções	Vulnerabilidade de aplicativo definida pelo modo como um aplicativo responde a erros inesperados que podem levar a falhas em sua segurança.
execução de código arbitrário.	Vulnerabilidade que permite a um invasor executar seu próprio código ou módulo que explore essa vulnerabilidade.
execução remota de código.	Vulnerabilidade que permite a um invasor transmitir código de um host remoto para execução em um host-alvo ou em um módulo que explora tal vulnerabilidade.
Exercício tabletop	Uma discussão de situações de emergência e incidentes de segurança simulados.
exfiltração de dados	O processo em que um invasor pega os dados armazenados dentro de uma rede privada e os move para uma rede externa.
expectativa de perda anual	Custo total de um risco para uma organização a cada ano. É determinada ao multiplicar a SLE pela taxa anual de ocorrência (ARO).
expectativa de perda única	Valor que seria perdido em uma única ocorrência de um determinado fator de risco.
Exportação de informações de fluxo de IP	Versão baseada em padrões da estrutura Netflow.
Exposição de dados	Vulnerabilidade de software em que um invasor é capaz de contornar os controles de acesso e obter dados confidenciais ou sensíveis do sistema de arquivos ou do banco de dados.
externo	Uma pessoa ou entidade responsável por um evento identificado como um incidente de segurança ou risco.
extorsão	Exigir pagamento para prevenir ou interromper algum tipo de ataque.

F

failover	Uma técnica que garante que um componente, dispositivo ou aplicativo redundante possa assumir de forma rápida e eficiente a funcionalidade de um ativo que falhou.
falha aberta	Configuração de controle de segurança que garante acesso contínuo ao recurso em caso de falha.
falha fechada	Configuração de controle de segurança que bloqueia o acesso a um recurso em caso de falha.
false negative (falso negativo)	Na verificação de segurança, designa um caso que não é relatado quando deveria.

false positive	Em verificação de segurança, designa um caso que é relatado quando não deveria.
Falsificação de solicitação do lado do servidor	Um ataque em que um invasor aproveita a confiança estabelecida entre o servidor e os recursos que pode acessar, incluindo ele mesmo.
Falsificação de solicitação entre sites	Um script mal-intencionado hospedado no site do invasor que pode explorar uma sessão iniciada em outro site no mesmo navegador.
Fator de exposição	No cálculo de risco, trata-se da porcentagem do valor de um ativo que seria perdida durante um incidente de segurança ou desastre.
fatores	No design de autenticação, diferentes tecnologias para implementar a autenticação, como conhecimento, propriedade/token e biometria/inerência. São caracterizados como algo que você sabe, tem ou é.
fechado/privado	Código de software ou pesquisa de segurança que permanecem como propriedade do desenvolvedor e só podem ser usados sob condições de licença permitidas.
federação	Processo que fornece a funcionalidade de login compartilhado em vários sistemas e empresas. De maneira geral, interconecta os serviços de gerenciamento de identidade de vários sistemas.
feed de ameaças	Assinaturas e regras de correspondência de padrões fornecidas a plataformas de análise como um feed automatizado.
feed de vulnerabilidades	Lista sincronizável de dados e scripts usados para verificar vulnerabilidades. Também conhecido como plug-ins ou testes de vulnerabilidade de rede (NVTs).
filtro da Web	Aplicativo ou gateway que filtra as solicitações de clientes de acordo com determinados tipos de conteúdo da Internet (Web, FTP, IM e assim por diante).
firewall baseado em host	Um aplicativo de software em execução em um único host e projetado para proteger apenas esse host.
firewall de aplicativo da web	Firewall desenvolvido especificamente para proteger o software executado em servidores Web e seus bancos de dados back-end contra ataques de injeção de código e DoS.
firewall de Camada 4	Um firewall de inspeção de estado que pode monitorar sessões TCP e tráfego UDP.
firewall de Camada 7	Firewall de inspeção com monitoração de estado que pode filtrar o tráfego com base em cabeçalhos e dados de protocolos específicos a aplicativos, como dados da Web ou de e-mail.
firewall de filtragem de pacotes	Tecnologia de firewall de camada 3 que compara cabeçalhos de pacotes com ACLs para determinar qual tráfego de rede será aceito.
firewall de inspeção stateful	Técnica usada em firewalls para analisar pacotes até a camada do aplicativo em vez de filtrar pacotes apenas por informações de cabeçalho, permitindo que o firewall imponha mais segurança.
firewall de roteador	Dispositivo de hardware que tem a função principal de um roteador, mas também possui funcionalidade de firewall embutida no firmware do roteador.

firewall de última geração	Avanços na tecnologia de firewall, desde o reconhecimento de aplicativos, filtragem baseada no usuário e prevenção de intrusões (IPS) até a inspeção por nuvem.
firewall do aparelho	Um dispositivo de hardware independente que executa apenas a função de um firewall, que é incorporado ao firmware do dispositivo.
forense digital	O processo de coletar e enviar evidências do computador para julgamento. A evidência digital é latente, ou seja, ela deve ser interpretada. Isso significa que precisamos de muita atenção para provar que a evidência não foi adulterada ou falsificada.
fraude	Falsificação de registros, como uma fraude interna que envolve manipulação de contas.
função essencial da missão	Atividade comercial ou organizacional crítica demais para ser interrompida por mais de algumas horas, ou de todo.
fusão de inteligência	Na busca por ameaças, trata-se do uso de fontes de dados de threat intelligence para automatizar a detecção de IoCs e TTPs adversários.

G

geofencing (delimitação geográfica)	Controle de segurança que pode impor um limite virtual com base na geografia real.
geolocalização	Identificação ou estimativa da localização física de um objeto, como uma fonte de radar, telefone celular ou dispositivo de computação conectado à Internet.
gerador de energia reserva	Uma fonte de alimentação reserva alimentada por diesel ou propano. No caso de falta de energia, uma UPS deve fornecer a energia de transição, pois um gerador de emergência não pode ser ativado com rapidez suficiente.
gerador de números aleatórios reais	Um método para gerar valores aleatórios a partir da amostragem de fenômenos físicos que têm uma alta taxa de entropia.
gerador de números pseudo-aleatórios	O processo pelo qual um algoritmo produz números que se aproximam da aleatoriedade sem serem verdadeiramente aleatórios.
gerenciador de senhas	Software que pode sugerir e armazenar senhas de sites e aplicativos para reduzir os riscos de más escolhas e comportamentos do usuário. A maioria dos navegadores possui um gerenciador de senhas integrado.
Gerenciamento de dispositivos móveis	Processamento e suporte a tecnologias para rastrear, controlar e proteger a infraestrutura móvel da organização.
Gerenciamento de eventos e informações de segurança	Solução que fornece análise em tempo real ou quase real de alertas de segurança gerados por hardware e aplicativos de rede.

gerenciamento de identidade e acesso	processo de segurança que fornece mecanismos de identificação, autenticação e autorização para usuários, computadores e outras entidades trabalharem com ativos organizacionais, como redes, sistemas operacionais e aplicativos. Também conhecido como gerenciamento de identidade (IdM) e gerenciamento de acesso.
gerenciamento de mudanças	Processo pelo qual mudanças na configuração dos sistemas de informação são implementadas como parte dos esforços gerais de gerenciamento de configurações da organização.
gerenciamento de patches	Identificar, testar e implantar atualizações do sistema operacional e de aplicativos. Os patches são frequentemente classificados como críticos, críticos para a segurança, recomendados e opcionais.
gerenciamento de riscos corporativos	Processo abrangente de avaliar, medir e mitigar os inúmeros riscos que ameaçam uma organização.
gerenciamento fora da banda	Acesso à interface administrativa de um dispositivo de rede usando uma rede separada da rede de dados habitual. Uma VLAN separada ou um tipo diferente de link podem ser usados, como, por exemplo, um modem dial-up.
gerenciamento unificado de ameaças	Aparelhos e agentes de segurança multifuncionais que combinam as funções de firewall, scanner de malware, detecção de intrusão, scanner de vulnerabilidade, prevenção contra perda de dados, filtragem de conteúdo e assim por diante.
gestão de configuração	Um processo pelo qual os componentes de sistemas de informação de uma organização são mantidos em um estado controlado que atenda aos requisitos da organização, incluindo os de segurança e conformidade.
gestão de risco	Processo cíclico de identificação, avaliação, análise e resposta aos riscos.
Global Positioning System (GPS) (Sistema de Posicionamento Global)	Meio de determinar a posição do receptor na Terra com base nas informações recebidas de satélites em órbita.
governança	Criação e monitoramento de políticas e procedimentos eficazes para gerenciar ativos, como dados, e garantir a conformidade com os regulamentos do setor e a legislação local, nacional e global.

H

hacker	Frequentemente usado para se referir a alguém que invade sistemas de computador ou espalha vírus; hackers éticos preferem ser vistos como especialistas e exploradores de sistemas de segurança computacional.
Hacktivista (hacktivista)	Um ator de ameaças motivado por uma questão social ou causa política.
hash	Função que converte uma entrada de cadeia de caracteres de tamanho arbitrário em uma saída de cadeia de caracteres de tamanho fixo. Isso é feito pelas funções de hash criptográficas de forma que a possibilidade de colisões é reduzida, considerando que duas entradas diferentes produziram o mesmo resultado.

honeypot (armadilha de mel)	Host (honeypot), rede (honeynet), arquivo (honeyfile) ou credencial/token (honeytoken) configurados com o objetivo de atrair invasores para longe de ativos de valor real e/ou de descobrir estratégias de ataque e pontos fracos na configuração de segurança.
-----------------------------	---

I

iD de radiofrequência	Um meio de codificação de informações em etiquetas passivas, que podem ser energizadas e lidas por ondas de rádio a partir de um dispositivo leitor.
identificação	O processo pelo qual uma conta de usuário e suas credenciais são emitidas para a pessoa correta. Às vezes chamado de registro ou inscrição.
identificação de riscos	Dentro da avaliação geral de riscos, trata-se do processo específico de listar fontes de risco devido a ameaças e vulnerabilidades.
identificador de segurança	O valor atribuído a uma conta pelo Windows e usado pelo sistema operacional para identificar essa conta.
identificador do conjunto de serviços	Cadeia de caracteres que identifica uma determinada LAN sem fio (WLAN).
iluminação de segurança	Mecanismos de segurança física que garantem que um local esteja suficientemente iluminado para que funcionários e hóspedes se sintam seguros e para que os sistemas de vigilância por câmera funcionem corretamente.
impacto	Gravidade do risco, se concretizado, medida por fatores como o escopo, valor do ativo ou impactos financeiros do evento.
implicit deny (negação implícita)	Um princípio básico de segurança que declara que, a menos que um acesso tenha sido explicitamente concedido, o acesso deve ser negado.
Impossible travel (viagem impossível)	Um possível indício de atividades mal-intencionadas em que as tentativas de autenticação são feitas a partir de diferentes locais num curto período.
inacessibilidade do recurso	Um possível indicador de atividades maliciosas em que um arquivo ou recurso de serviço que deveria estar disponível está inacessível.
incident (incidente)	Evento que interrompe as operações padrão ou compromete a política de segurança.
indicador de comprometimento	Um sinal de que um ativo ou rede foi atacado ou está atualmente sob ataque.
indicador-chave de risco	Método pelo qual os riscos emergentes são identificados e analisados para que as mudanças possam ser adotadas de modo a evitar proativamente a ocorrência de problemas.
indicadores de conteúdo bloqueado	Um possível indicador de atividades maliciosas em que os registros de auditoria mostram tentativas não autorizadas de ler ou copiar um arquivo ou outros dados.
informação proprietária	Informações criadas por uma organização, normalmente sobre os produtos ou serviços que ela fabrica ou fornece.
Informações financeiras	Dados mantidos sobre contas bancárias e de investimento, além de informações como folha de pagamento e declarações fiscais.

infraestrutura como um serviço	Modelo de serviços de nuvem que provisiona máquinas virtuais e infraestrutura de rede.
Infraestrutura de chave pública	Estrutura de autoridades de certificação, certificados digitais, software, serviços e outros componentes criptográficos implantados com a finalidade de validar a identidade dos requerentes.
infrastructure mode (modo de infraestrutura)	Arquitetura de provisionamento na qual a implantação de recursos é realizada por automação e orquestração com scripts.
injeção de comando	Caso em que um autor de ameaças consegue executar comandos de shell aleatórios em um host por meio de um aplicativo Web vulnerável.
injeção de memória	Vulnerabilidade que um invasor pode explorar para executar um código malicioso com o mesmo nível de privilégio do processo vulnerável.
injeção de SQL,	Um ataque em que o invasor acessa o lado do cliente do aplicativo para injetar uma consulta ao banco de dados nos dados de entrada direcionados a um servidor.
Input validation (validação de entrada)	Qualquer técnica usada para garantir que os dados inseridos em um campo ou variável em um aplicativo sejam tratados adequadamente por esse aplicativo.
Instituto Nacional de Padrões e Tecnologia	Agência governamental não regulatória que desenvolve padrões de segurança de computadores usados por agências federais dos EUA e publica guias e pesquisas de práticas recomendadas de segurança cibernética.
integrity (integridade)	A meta fundamental da segurança, de manter as informações organizacionais precisas, livres de erros e sem modificações não autorizadas.
inteligência artificial	Ciência de criar máquinas com a capacidade de desenvolver estratégias de análise e solução de problemas sem condução ou intervenção humana significativas.
Inteligência contra ameaças à reputação	Listas de bloqueio de fontes de ameaças conhecidas, como assinaturas de malware, números de endereços IP e domínios DNS.
Inteligência contra ameaças cibernéticas	O processo de investigação, coleta, análise e disseminação de informações sobre ameaças e fontes de ameaças emergentes.
Inteligência de código aberto	Informações publicamente disponíveis e as ferramentas usadas para agregá-las e pesquisá-las.
interface de programação de aplicativos	Métodos expostos por um script ou programa que permitem que outros scripts ou programas o usem. Por exemplo, uma API permite que os desenvolvedores de software acessem funções da pilha de protocolos TCP/IP em um sistema operacional (SO) específico.
interface homem-máquina	Controles de entrada e saída em um controlador de lógica programável (PLC) para permitir que o usuário configure e monitore o sistema.
Internet das Coisas	Dispositivos que podem relatar dados de estado e configuração e ser gerenciados remotamente por redes IP.
Internet Key Exchange (IKE - troca de chaves na Internet)	Framework para criar uma associação de segurança (SA) usada com o IPSec. Uma SA estabelece que dois hosts confiam um no outro (ao se autenticarem) e concordam sobre protocolos seguros e pacotes de codificação para usar na troca de dados.

Internet Protocol Security (IPSec - segurança de protocolo de Internet)	Conjunto de protocolos de rede usado para proteger dados por meio de autenticação e criptografia à medida que os dados trafegam pela rede ou pela Internet.
internet relay chat	Um protocolo de comunicações de grupo que permite aos usuários conversar, enviar mensagens privadas e compartilhar arquivos.
Interno/externo	O grau de acesso que um ator de ameaça possui antes de iniciar um ataque. Um autor de ameaça externo não possui privilégios permanentes, enquanto um ator interno possui algumas permissões de acesso.
interrupção do serviço	Um tipo de ataque que compromete a disponibilidade de um ativo ou processo de negócios.
invasor amador	Um invasor inexperiente e não qualificado que normalmente usa ferramentas ou scripts criados por outras pessoas.
isca	Um tipo de ataque que induz a vítima a usar ou abrir um dispositivo removível, documento, imagem ou programa que oculta um malware.
isenção de risco	Categoria de gestão de riscos que aceita um fator de risco não mitigado.
isolamento	Remoção ou restrição drástica dos caminhos de comunicação com um dispositivo ou sistema específico.

J

jailbreak	Remove o selo de proteção e quaisquer restrições específicas do sistema operacional para dar aos usuários maior controle sobre o dispositivo.
-----------	---

K

Kerberos	Serviço de autenticação e autorização de logon único baseado em um sistema de concessão de tíquete temporário.
keylogger	Software ou hardware mal-intencionado que pode registrar as teclas digitadas pelo usuário.
Kill chain	Um modelo desenvolvido pela Lockheed Martin que descreve os estágios pelos quais um ator de ameaças progride para uma invasão de rede.

L

LDAP Secure (LDAPS) (LDAP seguro)	Método de implementação de LDAP usando criptografia SSL/TLS.
Lei de Portabilidade e Responsabilidade dos Seguros de Saúde (Health Insurance Portability and Accountability Act)	Lei federal dos EUA que protege o armazenamento, leitura, modificação e transmissão de dados pessoais de saúde.

Lei Sarbanes-Oxley	Uma lei promulgada em 2002 que dita os requisitos para o armazenamento e retenção de documentos relacionados às operações financeiras e comerciais de uma organização.
Leitor de crachá	Mecanismo de autenticação que permite que um usuário apresente um cartão inteligente para operar um sistema de entrada.
leitor de proximidade	Scanner que lê dados de uma tag RFID ou NFC ao alcance.
Lesson 13, Topic B	Um padrão para encapsular comunicações EAP através de uma LAN (EAPoL) ou WLAN (EAPoW) para implementar autenticação baseada em porta.
Lesson 14, Topic A	Termo geral para os protocolos, as políticas e o hardware coletados que autenticam e autorizam o acesso a uma rede no âmbito do dispositivo.
Lesson 17, Topic A	Política que rege o uso de equipamentos e serviços de Internet da empresa pelos funcionários. Os ISPs também podem aplicar AUPs aos seus clientes.
Lesson 17, Topic A	Um plano documentado e com recursos que mostra as ações e responsabilidades que devem ser usadas em resposta a incidentes críticos.
levantamento do local	Documentação sobre um local com o intuito de criar uma infraestrutura wireless ideal. Geralmente contém os locais ideais para as antenas da rede sem fio e o posicionamento do access point (ponto de acesso) de maneira a fornecer a cobertura necessária aos clientes e a identificar fontes de interferência.
limpeza	O processo de remoção minuciosa e completa de dados de um meio de armazenamento de forma que vestígios dos arquivos não possam ser recuperados.
Linguagem de marcação de afirmação de segurança	Formato de dados baseado em XML usado para trocar informações de autenticação entre um cliente e um serviço.
linguagem de marcação extensiva	Um sistema para estruturar os documentos para que eles sejam legíveis por humanos e máquinas. As informações do documento são colocadas dentro de tags, que descrevem como essas informações são estruturadas.
linguagens de programação type-safe	Um programa que impõe uma verificação de tipo rigorosa durante a compilação e garante que variáveis e dados sejam usados corretamente. Isso evita vulnerabilidades relacionadas à memória e ataques de injeção.
linha cronológica válida.	Na perícia digital, refere-se a uma ferramenta que mostra a sequência de eventos do sistema de arquivos dentro de uma imagem de origem em formato gráfico.
linha de base segura	Guias de configuração, benchmarks e práticas recomendadas para implantar e manter um dispositivo de rede ou servidor de aplicativos em um estado seguro para sua função específica.
lista de bloqueios	Configuração de segurança em que o acesso geralmente é permitido a um processo de software, IP/domínio ou outra entidade, a menos que seja listado como explicitamente proibido.
Lista de materiais de software	Uma lista de informações detalhadas sobre os componentes e dependências de software usados em um aplicativo ou sistema.

lista de revogação de certificados	Lista de certificados que foram revogados antes da data de expiração.
Listener/collector	Dispositivo de rede que coleta ou recebe dados de log e/ou de estado advindos de outros sistemas de rede.
log de endpoint	Um destino para eventos relacionados à segurança gerados por agentes de detecção de intrusão e de malwares baseados no host.
Log de firewall	Um destino para dados de eventos relacionados a regras de acesso que foram configuradas para registro em log.
log de segurança	Destino para dados de eventos relacionados ao controle de acesso, como autenticação de usuários e uso de privilégios.
Log do aplicativo	Destino de dados de eventos relacionados a um aplicativo ou pacote de software específico.
Login único	Tecnologia de autenticação que permite a um usuário se autenticar uma vez e receber autorizações para vários serviços.
logs	O software do sistema operacional e dos aplicativos pode ser configurado para registrar eventos em log automaticamente. Isso fornece informações valiosas de solução de problemas. Os logs de segurança fornecem uma trilha de auditoria das ações realizadas no sistema, bem como avisos de atividades suspeitas. É importante que a configuração do registro de log e os arquivos sejam tornados invioláveis.
logs ausentes	Um possível indicador de atividades maliciosas onde eventos ou arquivos de log são excluídos ou adulterados.
logs de rede	Um destino para eventos de sistema e acesso gerado por um dispositivo de rede, como um switch, wireless access point ou roteador.

M

malware	Software que serve a um propósito mal-intencionado, normalmente instalado sem o consentimento (ou conhecimento) do usuário.
manipulador de exceções estruturado	Mecanismo para lidar com as condições de erro inesperadas que podem surgir durante a execução do código. O tratamento eficaz de erros reduz as chances de um programa ser explorado.
manobra	Na busca de ameaças, o conceito de que o ator e o defensor da ameaça podem usar estratégias de engano ou contra-ataque para obter vantagem posicional.
mapa de incidência	Diagrama que mostra em uma pesquisa da atividade Wi-Fi local a intensidade de sinal e a utilização de canais em diferentes locais.
maskamento de dados	Um método de desidentificação em que rótulos genéricos ou temporários são substituídos por dados reais, preservando a estrutura ou o formato dos dados originais. Também conhecido como ofuscação de dados.

matriz de responsabilidade	Dispõe que a responsabilidade pela implementação da segurança na transferência de aplicativos, dados e cargas de trabalho para uma plataforma em nuvem é compartilhada entre o cliente e o provedor de serviços em nuvem (CSP).
matriz de risco/mapa de calor	Tabela gráfica para consulta das partes interessadas que indica a probabilidade e o impacto dos fatores de risco identificados para um fluxo de trabalho, projeto ou departamento.
mecanismo de cache	Um recurso de muitos servidores proxy que permite que os servidores mantenham uma cópia das páginas web solicitadas com frequência.
Media Access Control (MAC filtering) (filtragem de controle de acesso ao meio)	Aplicação de uma lista de controle de acesso a um switch ou ponto de acesso, de modo que apenas clientes com endereços MAC aprovados possam se conectar a ele.
Memorando de Acordo	Documento legal que forma a base para que duas partes cooperem sem um contrato formal (um acordo de cooperação). MOAs são frequentemente usados por órgãos públicos.
Memorandum of Understanding (MOU) (memorando de entendimento)	Normalmente, um acordo preliminar ou exploratório para expressar a intenção de trabalhar em conjunto, que não é juridicamente vinculativo e não envolve a troca de dinheiro. Também pode definir funções e expectativas.
metadados	Informações armazenadas ou registradas como propriedade de um objeto, estado de um sistema ou transação.
microsserviços	Um módulo independente, de função única, com operações e interfaces bem definidas e leves. Normalmente, esse estilo de arquitetura permite a entrega rápida, frequente e confiável de aplicações complexas.
mitigação de riscos	A resposta de reduzir o risco para se encaixar dentro da disposição de uma organização em aceitar riscos.
modelo de implantação em nuvem	Classificação da propriedade e da gestão de uma nuvem como pública, privada, comunitária ou híbrida.
Modelo de objeto de documento	Quando os invasores enviam scripts maliciosos para a implementação de JavaScript do lado do cliente de um aplicativo da web para executar seu ataque apenas no cliente.
modelo de serviço em nuvem	Classificação da prestação de serviços em nuvem e o limite de responsabilidade do provedor de serviços de nuvem como software, plataforma, infraestrutura e assim por diante.
módulo de autenticação plugável	Uma estrutura para implementar provedores de autenticação no Linux.
Módulo de plataforma confiável	Especificação para armazenamento seguro baseado em hardware de chaves de criptografia, senhas com hash e outras informações de identificação do usuário e da plataforma.

Módulo de Segurança de Hardware	Dispositivo para gerar e armazenar chaves criptográficas. Este tipo de solução pode ser menos suscetível a adulterações e ameaças internas do que o armazenamento baseado em software.
Monitor do Sistema	Software que rastreia a integridade dos subsistemas de um computador usando métricas relatadas pelo hardware ou sensores do sistema. Isso propicia um serviço de alerta em caso de falhas como alta temperatura, intrusão no chassi e outras.
Monitoramento de integridade de arquivos	Tipo de software que analisa os arquivos do sistema para garantir que eles não tenham sido adulterados.
monitoramento de pacotes	Técnicas e ferramentas projetadas para mitigar os riscos de vulnerabilidades de aplicativos em códigos de terceiros, como bibliotecas e dependências.
monitoramento de rede	Software de auditoria que coleta informações de status e configuração de dispositivos de rede. Muitos produtos são baseados no Protocolo de Gerenciamento de Rede Simples (SNMP).
monitoramento/rastreamento de ativos	Software e processos de enumeração e inventário que garantem que os ativos físicos e de dados atendem aos níveis de referência de configuração e desempenho e não tenham sido adulterados ou sofrido outro tipo de acesso não autorizado.
movimento lateral	Processo pelo qual um invasor é capaz de se mover de uma região de um ambiente de computação a outra.
multifactor authentication (autenticação multifator)	Esquema de autenticação que exige que o usuário apresente pelo menos dois fatores diferentes como credenciais; por exemplo, algo que ele conhece, algo que ele tem, algo que ele é, algo que ele faz e algum lugar em que ele está. A especificação de dois fatores é conhecida como “2FA”.
multiplicador de força de trabalho	Ferramenta ou automatização que aumenta a produtividade dos funcionários, permitindo que eles executem mais tarefas com o mesmo padrão de qualidade por unidade de tempo.

N

não autorizado	Hacker que atua com más intenções.
Não repúdio.	Meta de segurança que visa garantir que o emissor de uma transmissão ou criador dos dados permaneça associado a esses dados e não possa negar o envio ou a criação desses dados.
NetFlow	Meios desenvolvidos pela Cisco para relatar informações de fluxo de rede para um banco de dados estruturado. O NetFlow possibilita uma melhor compreensão dos fluxos de tráfego de IP usados por diferentes hosts e aplicações de rede.
nível de criptografia	Alvo da criptografia de dados em repouso que varia da granularidade mais detalhada (arquivo ou linha/registro) à menos detalhada (volume/partição/disco ou banco de dados).

nível de sofisticação/capacidade	Classificação formal dos recursos e conhecimentos disponíveis a um autor de ameaças.
no-break	Dispositivo a bateria que fornece energia CA a dispositivos eletrônicos em caso de falta de energia.
nome alternativo do assunto	Campo em um certificado digital que permite identificar um host por vários nomes/subdomínios de host.
nome comum	Atributo x500 que expressa um host ou nome de usuário, também usado como identificador de assunto para um certificado digital.
Nondisclosure Agreement (NDA) (contrato de confidencialidade)	Acordo que estipula que as entidades não compartilharão informações confidenciais, conhecimento ou materiais com terceiros não autorizados.
Notação de objeto JavaScript	Formato de arquivo que usa pares de atributo-valor para definir configurações em uma estrutura que facilita a leitura e o consumo por humanos e máquinas.
número de identificação pessoal	Um número usado em conjunto com dispositivos de autenticação, como cartões inteligentes; como o PIN deve ser conhecido apenas pelo usuário, a perda do cartão inteligente não deve representar um risco à segurança.
nuvem híbrida	Implantação de nuvem que usa elementos privados e públicos.
nuvem privada virtual	Um segmento de rede privada disponibilizado para um único consumidor de nuvem em uma nuvem pública.

O

O alongamento de chave	Técnica que fortalece informações potencialmente fracas para fins de geração de chaves criptográficas, como senhas ou frases de desbloqueio criadas por pessoas, contra ataques de força bruta.
o risco residual	Risco que permanece mesmo após os controles serem implementados.
O teste de penetração defensiva	A equipe defensiva em um teste de penetração ou exercício de resposta a incidentes.
O teste de penetração ofensiva	A equipe “hostil” ou invasora em um teste de penetração ou exercício de resposta a incidentes.
objetivo de tempo de recuperação	Tempo máximo permitido para restaurar um sistema após um evento de falha.
objetivo do ponto de recuperação	Período mais longo pelo qual uma organização pode tolerar que os dados perdidos sejam irrecuperáveis.
objeto de política de grupo	Em um domínio do Windows, uma maneira de implantar configurações por usuário e por computador, como política de senha, restrições de conta, status de firewall e assim por diante.
obuscação	Técnica que essencialmente “oculta” ou “camufla” códigos ou outras informações para dificultar mais sua leitura por usuários não autorizados.

oficial de segurança de sistemas de informação	Função organizacional com responsabilidades técnicas pela implementação de políticas, estruturas e controles de segurança.
onboarding	O processo de integração de um novo funcionário, prestador de serviços ou fornecedor.
Opal	Padrões para implementar a criptografia de dispositivos em dispositivos de armazenamento.
open public ledger	Registro público distribuído de transações que sustenta a integridade das blockchains.
operational technology	Rede de comunicações projetada para implementar um sistema de controle industrial, em vez de uma rede de dados.
ordem de volatilidade	A ordem na qual os dados voláteis devem ser recuperados de vários locais e dispositivos de armazenamento após a ocorrência de um incidente de segurança.
organização de compartilhamento de informações	Grupos colaborativos que trocam dados sobre vulnerabilidades e ameaças emergentes à segurança cibernética.
Os inventários de dados	Lista de informações ou dados confidenciais armazenados ou processados por um sistema.

P

padrões	Resultado esperado ou estado de uma tarefa que foi executada de acordo com as políticas e procedimentos. Os padrões podem ser determinados internamente ou medidos em relação a parâmetros externos.
padrões de criptografia de chave pública	Série de padrões que definem o uso de autoridades de certificação e certificados digitais.
painel de eventos	Um console que apresenta informações selecionadas em um formato facilmente assimilável, como uma visualização.
partes interessadas	Pessoa que tem interesse comercial no resultado de um projeto ou está ativamente envolvida no seu trabalho.
passivo	Dispositivo de hardware inserido em um cabeamento visando copiar quadros para fins de análise.
patch (correção)	Uma pequena unidade de código suplementar destinada a resolver um problema de segurança ou uma falha de funcionalidade em um pacote de software ou sistema operacional.
Payment Card Industry Data Security Standard (PCI DSS) (Padrão de segurança de dados do setor de cartões de pagamento)	Padrão de segurança da informação para organizações que processam pagamentos com cartão de crédito ou bancário.
pentest	Um Pentest é um teste que utiliza ferramentas ativas e utilitários de segurança para avaliar a segurança, simulando um ataque a um sistema. O Pentest verifica a existência de uma ameaça, testa e contorna controles de segurança de forma ativa e, por fim, explora vulnerabilidades no sistema.

Perfect Forward Secrecy	Característica da criptografia de transporte que garante que, se uma chave for comprometida, isso afetará apenas uma única sessão e não facilitará a recuperação de dados de texto simples de outras sessões.
permissions (permissões)	Configurações de segurança que controlam o acesso a objetos, incluindo itens do sistema de arquivos e recursos de rede.
persistência (balanceamento de carga)	Em balanceamento de carga, a opção de configuração que permite que um cliente mantenha uma conexão com um servidor com carga balanceada durante a sessão. Também chamadas de sticky sessions (sessões persistentes ou fixas).
personificação	Ataque de engenharia social em que um invasor finge ser alguém que não é.
pharming	Ataque de personificação em que a solicitação de acesso a um site, normalmente um site de comércio eletrônico, é redirecionada a um site de aparência semelhante mas falso.
phishing	Ataque de engenharia social baseado em e-mail no qual o invasor envia e-mail de uma fonte supostamente credível, como um banco, para tentar obter informações privadas da vítima.
pivoting	Quando um invasor usa um host comprometido (o pivô) como uma plataforma a partir da qual é possível espalhar um ataque para outros pontos da rede.
planejamento de capacidade	Uma prática que envolve estimar os recursos de pessoal, armazenamento, hardware e software de computadores e infraestrutura de conexão que serão necessários durante algum período futuro.
plano de controle (confiança zero)	Na arquitetura de confiança zero, refere-se às funções que definem a política e determinam as decisões de acesso.
plano de resposta a incidentes	Procedimentos específicos que devem ser executados se um determinado tipo de evento for detectado ou relatado.
Planos de continuidade dos negócios	Coleção de processos que permitem a uma organização manter operações comerciais normais diante de algum evento adverso.
Plataforma como serviço	Modelo de serviços de nuvem que provisiona serviços de aplicativos e banco de dados como uma plataforma para o desenvolvimento de aplicativos.
playbook (manual)	Uma lista de verificação de ações a serem executadas para detectar e responder a um tipo específico de incidente.
política de melhores práticas de senha	Regras que controlam a escolha e manutenção seguras dos segredos de autenticação do fator de conhecimento, como tamanho, complexidade, idade e reutilização.
política de mesa limpa	Política organizacional que exige que as áreas de trabalho dos funcionários estejam livres de informações potencialmente confidenciais; documentos confidenciais não devem ser deixados à vista de pessoas não autorizadas.
políticas	Conjunto de regras estritamente aplicável que determina como uma tarefa deve ser concluída.

políticas de conta	Conjunto de regras que regem as informações de segurança do usuário, como expiração e exclusividade da senha, e que podem ser definidas para ter aplicação global.
Políticas de segurança da informação	Documento ou série de documentos respaldados pela gerência sênior e que detalha os requisitos para proteger os ativos de tecnologia e de informação contra ameaças e uso indevido.
Ponto único de falha	Componente ou sistema que causaria uma interrupção completa de um serviço se ele falhasse.
port security (segurança da porta)	Impedir que um dispositivo conectado a uma porta de switch se comunique na rede, a menos que corresponda a um determinado endereço MAC ou outro perfil de proteção.
posicionamento do dispositivo	Considerações a serem feitas para posicionar controles de segurança a fim de proteger zonas de rede e hosts individuais, implementar uma estratégia de defesa em profundidade e atender às metas gerais de segurança.
preparação	Processo de resposta a incidentes que fortalece sistemas, define políticas e procedimentos, estabelece linhas de comunicação e implementa recursos.
pretexto	Tática de engenharia social em que uma equipe comunica, direta ou indiretamente, uma mentira ou meia-verdade para levar alguém a acreditar em uma falsidade.
prevenção de perda/vazamento de dados	Solução de software que detecta e impede que informações confidenciais sejam armazenadas em sistemas não autorizados ou transmitidas por redes não autorizadas. Também conhecido como "DLP".
prevenção de riscos	Na mitigação de riscos, trata-se da prática de cessar a atividade que apresenta risco.
primeiro agente de resposta	A primeira pessoa ou equipe experiente a chegar ao local de um incidente.
primitiva criptográfica	Uma única função hash, cifra simétrica ou cifra assimétrica.
Privacidade equivalente com fio	Um mecanismo legado para criptografar dados enviados através de uma conexão wireless.
private cloud (nuvem privada)	Uma nuvem implantada para uso por uma única entidade.
Privileged Access Management (PAM - Gestão de acesso privilegiado)	Políticas, procedures (procedimentos) e software de suporte para gerenciar contas e credenciais com permissions (permissões) administrativas.
privilégio mínimo	Um princípio básico de segurança que define que algo deve receber os direitos, privilégios ou informações mínimos necessários para desempenhar sua função. Também conhecido como princípio do privilégio mínimo.
probabilidade	Em matéria de análise qualitativa de risco, trata-se da chance de um evento ocorrer, expressa em uma escala determinada subjetivamente como alta ou baixa.
Probabilidade (risco)	Medida matemática da possibilidade de ocorrência de um risco.

procedure (procedimento)	Instruções detalhadas para realizar uma tarefa de forma a manter a conformidade com políticas e padrões.
processador de dados	Na regulamentação de privacidade, trata-se de uma entidade à qual foi confiada uma cópia dos dados pessoais para realizar o armazenamento e/ou análise em nome do coletor de dados.
processo de análise	Processo de resposta a incidentes no qual indicadores são avaliados para determinar a validade, o impacto e a categoria.
processo de erradicação	Processo de resposta a incidentes no qual se removem as ferramentas e configurações mal-intencionadas em hosts e redes.
processo malicioso	Processo executado sem a devida autorização do proprietário do sistema com a finalidade de danificar ou comprometer o sistema.
programa de divulgação responsável	Um processo que permite que pesquisadores e revisores divulguem vulnerabilidades com segurança a um desenvolvedor de software.
programa potencialmente indesejado	Software que não pode ser definitivamente classificado como mal-intencionado, mas que pode não ter sido escolhido ou desejado pelo usuário.
programas de recompensa por bugs	Esquema de recompensa operado por fornecedores de software e serviços Web para relatar vulnerabilidades.
propriedade da empresa, habilitado pessoalmente	Modelo de provisionamento de dispositivos móveis corporativos no qual o aparelho permanece como propriedade da organização mas com permissões para certos fins pessoais, como email privado, redes sociais e navegação na Web.
propriedade da empresa, somente para negócios	Modelo de provisionamento de dispositivos móveis corporativos no qual o dispositivo pertence à organização e o uso pessoal é proibido.
proprietário dos dados	Cargo sênior (executivo) com responsabilidade final por manter a confidencialidade, integridade e disponibilidade de um ativo de informação.
Protocolo AES Galois Counter Mode	Modo de operação de alto desempenho para criptografia simétrica. Conta com uma característica especial chamada criptografia autenticada com dados associados, ou AEAD.
Protocolo de acesso a mensagem da internet	Protocolo de aplicativo que fornece um meio para o cliente acessar e gerenciar mensagens de email armazenadas na caixa de correio em um servidor remoto. O IMAP4 utiliza a porta TCP número 143, enquanto a versão segura IMAPS utiliza a TCP/993.
Protocolo de área de trabalho remota	Protocolo de aplicativo para operar conexões remotas em um host usando uma interface gráfica. O protocolo envia dados da tela do host remoto ao cliente e transfere os comandos do mouse e do teclado do cliente ao host remoto. Para isso, usa-se a porta TCP 3389.

Protocolo de autenticação extensível	Estrutura para negociar métodos de autenticação que permitem que os sistemas usem identificadores baseados em hardware, como scanners de impressão digital ou leitores de cartões inteligentes, para autenticação e estabeleçam túneis seguros para enviar credenciais.
Protocolo de automação de conteúdo de segurança	Uma estrutura NIST que descreve várias práticas aceitas para automatizar a varredura de vulnerabilidades.
protocolo de integridade de chave temporal	Mecanismo usado na primeira versão do WPA para melhorar a segurança dos mecanismos de criptografia wireless, em comparação com o falho padrão WEP.
Protocolo de Internet	Protocolo da camada de rede (Internet) no conjunto de protocolos TCP/IP fornecendo endereçamento e roteamento de pacotes a todos os protocolos de nível mais alto no conjunto.
Protocolo de resolução de endereços (ARP) (Address Resolution Protocol)	Mecanismo de transmissão pelo qual o endereço MAC do hardware de uma interface é combinado a um endereço IP em um segmento de rede local.
protocolo de status do certificado on-line	Permite que os clientes solicitem o status de um certificado digital para verificar se ele foi revogado.
Protocolo de transferência de arquivo	Protocolo de aplicativo usado para transferir arquivos entre hosts de rede. As variantes incluem SFTP, ou Secure FTP; FTP com SSL (FTPS e FTPES); e TFTP, ou Trivial FTP. O FTP utiliza as portas 20 e 21.
Protocolo de tunelamento ponto a ponto	Desenvolvido pela Cisco e Microsoft para VPNs por PPP e TCP/IP. O PPTP é altamente vulnerável a ataques de quebra de senha e considerado obsoleto.
Protocolo dos correios	Protocolo de aplicativo que permite que um cliente baixe mensagens de email de uma caixa de correio do servidor para um cliente pela porta TCP/110 ou porta segura TCP/995.
Protocolo leve de acesso de diretório	Protocolo usado para acessar bancos de dados de diretório de rede, que armazenam informações sobre usuários autorizados e seus privilégios, bem como outras informações organizacionais.
Protocolo simples de acesso a objetos	Protocolo de serviços da Web baseado em XML que é usado para trocar mensagens.
Protocolo simples de gerenciamento de rede	Protocolo de aplicativo usado para monitorar e gerenciar dispositivos de rede. O SNMP usa as portas UDP 161 e 162, por padrão.
provedor de identidade	Em uma rede federada, o serviço que mantém a conta do usuário e executa a autenticação.
Provedor de serviços em nuvem	Organização que fornece serviços de infraestrutura, aplicativos e/ou armazenamento por meio de uma oferta baseada em assinatura “como serviço” e centrada na nuvem.
proveniência	Na análise forense digital, refere-se a ser capaz de rastrear a fonte de evidências até uma cena de crime e mostrar que ela não foi adulterada.

provisionamento	Processo de implantação de uma conta, host ou aplicativo em um ambiente de produção-alvo. Isto envolve comprovar a identidade ou integridade do recurso e conceder-lhe credenciais e permissões de acesso.
proxy não transparente	Um servidor que redireciona solicitações e respostas para clientes configurados com o endereço e a porta do proxy.
proxy transparente	Um servidor que redireciona solicitações e respostas sem que o cliente seja explicitamente configurado para usá-lo. Também chamado de proxy forçado ou de interceptação.
Público (ou multilocatário)	Nuvem que é implantada para uso compartilhado por vários locatários independentes.

Q

Na gestão de fornecedores, trata-se de meios estruturados de obtenção de questionários informações consistentes, possibilitando análises e comparações de riscos mais eficazes.

R

ransomware	Malware que tenta extorquir a vítima bloqueando o funcionamento normal de um computador e/ou criptografando os arquivos da vítima e exigindo pagamento.
raspagem	Duplicar um cartão de acesso por aproximação copiando seu token de acesso e programando um novo cartão com os mesmos dados.
reconhecimento	As ações tomadas para coletar informações sobre o software ou os sistemas de computador de um indivíduo ou organização. Normalmente envolve a coleta de informações, como os tipos de sistemas e software utilizados, informações sobre a conta do usuário, tipos de dados e configuração de rede.
reconhecimento ativo	Técnicas de teste de penetração que interagem diretamente com os sistemas-alvo.
reconhecimento de comportamento anômalo	Sistemas que detectam automaticamente usuários, hosts e serviços que se desviam do esperado, ou sistemas e treinamentos que incentivam a denúncia disso pelos funcionários.
reconhecimento passivo	Técnicas de teste de penetração que não interagem diretamente com os sistemas-alvo.
recuperação	Um processo de resposta a incidentes no qual hosts, redes e sistemas são revertidos a uma configuração de linha de base segura.
recuperação	A operação para recuperar a funcionalidade do sistema e/ou a integridade dos dados usando mídias de backup.
recursos/financiamento	Capacidade dos autores de ameaças de obter por meio de financiamento ferramentas e pessoal e desenvolver novos tipos de ataque.
rede ad hoc	Tipo de rede wireless em que dispositivos conectados se comunicam diretamente entre si em vez de usar um meio estabelecido.

rede de área pessoal	Escopo de rede que usa tecnologias wireless de curto alcance (geralmente baseadas em Bluetooth ou NFC) para estabelecer comunicações entre dispositivos pessoais, como smartphones, notebooks e impressoras/periféricos.
rede insegura	Configuração que expõe uma grande superfície de ataque: por exemplo, por meio de portas de serviço abertas desnecessariamente, autenticação fraca ou inexistente, uso de credenciais padrão ou falta de comunicações/criptografia seguras.
rede local	Centro de rede privada pertencente e operado por uma organização para uso exclusivo de seus funcionários.
rede local virtual	Segmento de rede lógico que compreende um domínio de transmissão estabelecido usando um recurso de switches gerenciados para atribuir a cada porta um ID de VLAN. Mesmo que os hosts em duas VLANs possam estar conectados fisicamente ao mesmo switch, o tráfego local é isolado para cada VLAN, então elas precisam de um roteador para se comunicar.
Rede virtual privada	Túnel seguro criado entre dois endpoints conectados via rede de transporte não segura (geralmente a Internet).
redundância	Provisionamento excedente de recursos no âmbito do componente, host e/ou local de modo a que haja um processo automatizado de transição a uma instância operacional em caso de problemas.
registro de riscos	Documento que destaca os resultados das avaliações de risco em um formato facilmente compreensível (como um quadro com sinais em verde, amarelo e vermelho). Seu objetivo é fazer com que os gerentes de departamento e técnicos entendam os riscos associados aos fluxos de trabalho que gerenciam.
registro em diário	Método usado pelos sistemas de arquivos para registrar alterações ainda não feitas ao sistema de arquivos em um objeto chamado journal.
registro em diário	Servidor reforçado que dá acesso a outros hosts.
registro em log fora de ciclo	Um possível indicador de atividades maliciosas em que as datas ou registros de hora dos eventos não são consistentes.
Regras de engajamento	Uma definição de como um teste de penetração será executado e quais restrições estarão em vigor. Isso fornece diretrizes para consultar ao testador de penetração enquanto ele realiza seus testes, de forma que não seja preciso pedir constantemente permissão à gerência para fazer algo.
Regulamento Geral de Proteção de Dados	Disposições e requisitos que protegem os dados pessoais de cidadãos da União Europeia (UE). As transferências de dados pessoais para fora do mercado único da União Europeia são restritas, a menos que protegidas por regulamentos semelhantes, como os requisitos do Privacy Shield dos EUA.
relatório de lições aprendidas	Uma análise de eventos que podem fornecer informações sobre como melhorar os processos de resposta e suporte no futuro.
relatório de risco	Resumo periódico de informações relevantes sobre os riscos atuais de um projeto. Proporciona uma visão geral resumida dos riscos conhecidos e percebidos, bem como de seu impacto na organização.

relatórios (forenses)	Processo forense que resume conteúdos significativos de dados digitais usando métodos e ferramentas abertos, repetíveis e imparciais.
remote access Trojan	Malware que cria um canal de administração remota (backdoor) para permitir que um ator de ameaça acesse e controle o host infectado.
replay attack (ataque por repetição)	Ataque em que o invasor intercepta dados de autenticação e os reutiliza para tentar restabelecer uma sessão.
replicação de dados	Cópia automática de dados entre dois sistemas de processamento que ocorre simultaneamente em ambos os sistemas (síncrono) ou de um local primário para um secundário (assíncrono).
resiliência	A capacidade de um sistema ou rede de se recuperar rapidamente de eventos de falha com nenhuma ou mínima intervenção manual.
responsável pelo risco	Indivíduo responsável por desenvolver e implementar uma estratégia de resposta a riscos para um risco documentado em um registro de riscos.
responsividade	Capacidade de um sistema de processar uma tarefa ou carga de trabalho em um prazo aceitável.
restrições de hora do dia	Políticas ou definições de configuração que limitam o acesso de um usuário a recursos.
Retenção de dados	Processo que uma organização usa para manter a existência e o controle de determinados dados a fim de cumprir as políticas de negócios e/ou as leis e regulamentos aplicáveis.
Retenção legal	Processo destinado a preservar todas as informações relevantes quando há uma expectativa razoável de litígio.
risco	Probabilidade e impacto (ou consequência) de um ator de ameaça explorar uma vulnerabilidade.
risco inerente	Risco representado por um evento se nenhum controle for implementado para mitigá-lo.
Rooting	Obtenção de acesso em nível de superusuário em um dispositivo móvel com sistema operacional Android.
rootkit	Classe de malware que modifica os arquivos do sistema, geralmente no âmbito do kernel, para ocultar sua presença.

S

salt	Uma contramedida de segurança que adiciona um valor aleatório (“salting”) a cada entrada de texto simples para mitigar o impacto de ataques de tabela de hashes pré-computados.
sandbox (área restrita)	Ambiente de computação isolado de um sistema host para garantir que o ambiente seja executado de maneira controlada e segura. Em geral, links de comunicação entre a área restrita e o host são completamente proibidos, de modo que o malware ou o software defeituoso possa ser analisado isoladamente e sem risco para o host.
scalability (escalabilidade)	Propriedade pela qual um ambiente de computação consegue atender de forma equilibrada a suas necessidades de recursos cada vez maiores.

scanner antivírus	Software capaz de detectar e remover infecções por vírus e (na maioria dos casos) outros tipos de malware, como worms, cavalos de Troia, rootkits, adware, spyware, crackers de senha, mapeadores de rede, ferramentas de DoS e assim por diante.
scanner de vulnerabilidades	Hardware ou software configurado com uma lista de vulnerabilidades e explorações conhecidas e que pode verificar sua presença no sistema operacional de um host ou um aplicativo específico.
screened subnet (sub-rede filtrada)	Segmento isolado do resto de uma rede privada por um ou mais firewalls que aceita conexões da Internet pelas portas designadas. Conhecida anteriormente como zona desmilitarizada (DMZ), essa nomenclatura é obsoleta.
Secure Access Service Edge (SASE - borda de serviço de acesso seguro)	Uma arquitetura de rede e segurança que fornece acesso seguro a aplicativos e serviços em nuvem, reduzindo a complexidade. Combina serviços de segurança como firewalls, gestão de identidade e acesso e um gateway Web seguro com serviços de rede, como SD-WAN.
Secure File Transfer Protocol (SFTP) (protocolo de transferência protegida de arquivos)	Uma versão segura do protocolo FTP que usa um túnel Secure Shell (SSH) como método de criptografia para transferir, acessar e gerenciar arquivos.
Secure Shell	Protocolo de aplicativo que suporta tunelamento seguro, emulação de terminal remoto e cópia de arquivos. O SSH é executado via TCP na porta 22.
segmentação lógica	Topologia de rede imposta pela configuração de switch, roteador e firewall na qual os hosts em um segmento de rede são impedidos ou restritos na comunicação com hosts em outros segmentos.
segredos comerciais	Propriedade intelectual que dá a uma empresa uma vantagem competitiva mas que não foi registrada com direitos autorais, marcas comerciais ou patentes.
seleção de controles eficazes	O processo de escolher o tipo e o posicionamento de controles de segurança para garantir os objetivos da tríade CIA e o cumprimento de quaisquer requisitos da estrutura.
SELinux	Esquema padrão de permissões baseado em contexto que é fornecido com o CentOS e Red Hat Enterprise Linux.
sem senha	Esquema de autenticação multifatorial que usa fatores de propriedade e biométricos, mas não fatores de conhecimento.
senha de uso único	Senha gerada para uso em uma sessão específica e que se torna inválida após o término da sessão.
sensor (monitor)	Um monitor que registra (ou detecta) dados dos quadros à medida que passam pelos meios de rede usando métodos como uma porta espelhada ou dispositivo TAP (Test Access Point).
Sensores	Componente em um sistema de alarme que identifica a entrada não autorizada por meio da detecção de movimentos ou mudanças térmicas baseada em infravermelho, ultrassom, micro-ondas ou pressão.

server-side attack (ataque do lado do servidor)	Em um aplicativo da web, dados de entrada que são executados ou validados como parte de um script ou processo em execução no servidor.
serviço de diretório	Um serviço de rede que armazena informações de identidade sobre todos os objetos em uma rede específica, incluindo usuários, grupos, servidores, computadores clientes e impressoras.
Serviço RADIUS (serviço de autenticação da Internet da Microsoft)	Protocolo AAA usado para administrar infraestruturas de autenticação remota e sem fio.
servidor proxy	Servidor que medeia as comunicações entre um cliente e outro servidor. Pode filtrar e, muitas vezes, modificar as comunicações, além de fornecer serviços de armazenamento em cache para melhorar o desempenho. Também chamado de proxy de encaminhamento.
servidor proxy reverso	Um tipo de servidor proxy que protege os servidores do contato direto com as solicitações do cliente.
shellcode (código shell)	Bloco leve de código mal-intencionado que explora uma vulnerabilidade de software para obter acesso inicial a um sistema da vítima.
sideload	Instalação de um aplicativo em um dispositivo móvel sem usar a loja de aplicativos.
Simple Mail Transfer Protocol (SMTP) (protocolo de transferência de correio simples)	Protocolo de aplicativo usado para enviar e-mail entre hosts na Internet. As mensagens são enviadas entre os servidores pela porta TCP 25 ou por um cliente de e-mail pela porta segura TCP/587.
simulação (teste)	Técnica de teste que replica as condições de um cenário de desastre ou incidente de segurança real.
sinkhole	Estratégia de mitigação de ataques DoS que redireciona para outra rede o tráfego que estiver sobrecarregando (flooding) um endereço IP-alvo para fins de análise.
sistema de controle industrial	Dispositivos integrados de gerenciamento de rede (sistemas de computador projetados para executar uma função específica e dedicada).
Sistema de detecção de intrusão	Um software ou dispositivo de segurança que analisa dados de um sniffer de pacotes para identificar o tráfego que viola políticas ou regras. Também chamado de network intrusion detection system (NIDS) (sistema de detecção de intrusão de rede).
sistema de detecção de intrusão baseado em host	Um tipo de sistema de detecção de intrusão que monitora um sistema de computador em busca de comportamento inesperado ou mudanças drásticas no estado do sistema.
sistema de gerenciamento de chaves	Em PKI, procedimentos e ferramentas que centralizam a geração e o armazenamento de chaves criptográficas.

Sistema de pontuação de vulnerabilidade comum (Common Vulnerability Scoring System - CVSS)	Uma abordagem de gestão de risco para quantificar dados de vulnerabilidade e considerar o grau de risco para diferentes tipos de sistemas ou informações.
Sistema de posicionamento interno	Tecnologia que pode obter a localização de um dispositivo em um ambiente fechado traçando um triângulo baseado na sua proximidade a fontes de rádio, como beacons Bluetooth ou access points Wi-Fi.
sistema de prevenção de intrusão baseado em host	Proteção de endpoint que pode detectar e prevenir atividades maliciosas por meio de assinatura e de detecção heurística de padrões.
sistema operacional em tempo real	Um tipo de sistema operacional que prioriza a execução determinística das operações para garantir uma resposta consistente para tarefas com prazos críticos.
Sistemas e aplicativos sem suporte	Fase do ciclo de vida do produto na qual o suporte do fornecedor principal não está mais disponível.
site cold	Um local alternativo predeterminado onde uma rede pode ser reconstruída após um desastre.
site hot	Local de processamento alternativo totalmente configurado que pode ser colocado online de maneira instantânea ou muito rápida após um desastre.
site warm	Local de processamento alternativo que está inativo ou executa funções não essenciais em condições normais, mas que pode ser rapidamente convertido em um local de operações chave, se necessário.
smart card (cartão inteligente)	Dispositivo de segurança semelhante a um cartão de crédito que pode armazenar informações de autenticação, como a chave privada de um usuário, em um criptoprocessador incorporado.
SMiShing	Forma de phishing que usa mensagens de texto SMS para induzir a vítima a revelar informações.
snapshot (backup)	Usado para criar toda a instância arquitetônica/cópia de um aplicativo, disco ou sistema. É frequentemente usado em processos de backup para fornecer pontos de reversão que podem restaurar o sistema ou o disco de um determinado dispositivo para um momento específico. Embora os snapshots ajudem nas estratégias de backup, eles não são iguais aos backups de imagem e dependem dos dados originais.
Snort	Um IDPS de código aberto. É necessária uma assinatura ("oinkcode") para obter conjuntos de regras atualizados que permitem que o mecanismo de detecção identifique as ameaças mais recentes. Os assinantes podem obter conjuntos de regras criados pela comunidade.
social engineering (engenharia social)	Usar persuasão, manipulação ou intimidação para fazer a vítima violar uma política de segurança. O objetivo da engenharia social pode ser obter acesso a uma conta, a instalações físicas ou coletar informações.

Software como serviço	Um modelo de serviços de nuvem que provisiona serviços de aplicativos totalmente desenvolvidos para os usuários.
software composition analysis (SCA)	Ferramentas projetadas para auxiliar na identificação de códigos de terceiros e de código aberto durante o desenvolvimento e implantação de software.
Software vulnerável	Ponto fraco que pode ser desencadeado acidentalmente ou explorado de maneira intencional para causar uma violação de segurança.
Software-Defined Networking (rede definida por software)	APIs e hardware/dispositivos virtuais compatíveis que permitem dispositivos e sistemas de rede programáveis.
solicitação de assinatura de certificado	Um arquivo Base64 ASCII que um sujeito envia a uma CA para obter um certificado.
spraying de senha	Ataque de força bruta em que várias contas de usuário são testadas com um dicionário de senhas comuns.
spyware	Software que registra informações sobre um computador e seus usuários por vezes instalado sem o consentimento destes.
sumidouro de DNS	Registro DNS temporário que redireciona o tráfego mal-intencionado para um endereço IP controlado.
Superfície de ataque	Os pontos em que uma rede ou aplicativo recebe conexões externas ou entradas/saídas que são vetores potenciais a serem explorados por um ator de ameaça.
supplicant	Na arquitetura EAP, trata-se do dispositivo que está solicitando acesso à rede.
SYN flood	Ataque DoS em que o invasor envia várias solicitações SYN a um servidor-alvo na esperança de consumir recursos suficientes para impedir a transferência de tráfego legítimo.
syslog	Protocolo de aplicativo e formato de registro de eventos que permitem que diferentes dispositivos e aplicativos de software transmitam logs ou registros de eventos a um servidor central. O syslog usa porta UDP 514, por padrão.

T

tabela de estado	Informações sobre sessões entre hosts coletadas por um firewall com monitoração de estado.
tamanho da chave	Tamanho de uma chave criptográfica em bits. As chaves mais longas geralmente oferecem mais segurança, mas os tamanhos de chaves encontrados em cifras diferentes não podem ser diretamente comparados entre si.
Táticas, técnicas e procedimentos	Análise de ataques cibernéticos históricos e ações adversárias.
taxa anual de ocorrência	No cálculo de risco, trata-se de uma expressão da probabilidade/possibilidade de um risco como o número de vezes por ano que uma perda específica pode ocorrer.

taxa de erro de cruzamento	Um fator de avaliação de biometria que expressa o ponto em que FAR e FRR se encontram, com um valor baixo indicando melhor desempenho.
taxa de falsa aceitação	Uma métrica de avaliação biométrica que mede o número de usuários não autorizados a quem o acesso é permitido por engano.
taxa de rejeição falsa	Uma métrica de avaliação biométrica que mede o número de indivíduos válidos a quem o acesso é negado.
tempo de inatividade máximo tolerável	Período mais longo pelo qual um processo pode ficar inoperante sem causar falha irreversível para a empresa.
tempo de reação	Tempo decorrido entre a ocorrência de um incidente e a implementação de uma resposta.
tempo de recuperação do trabalho	Na recuperação de desastres, o tempo adicional ao RTO de sistemas individuais para realizar a reintegração e o teste de um sistema restaurado ou atualizado após um evento.
tempo de verificação para tempo de uso	A vulnerabilidade potencial que ocorre quando há uma alteração entre quando um aplicativo verificou um recurso e quando o aplicativo usou o recurso.
tempo médio entre falhas	métrica de um dispositivo ou componente que prevê o tempo esperado entre falhas.
tempo médio para reparo/substituição/recuperação	Métrica que representa o tempo médio necessário para que um dispositivo ou componente seja reparado, substituído ou recuperado de uma falha.
testes de penetração física	Técnicas de avaliação que se estendem ao local e a outros sistemas de segurança física.
Testes de penetração integrados	Abordagem holística que combina diferentes tipos de metodologias e técnicas de teste de penetração para avaliar as operações de segurança de uma organização.
testes de processamento paralelo	Execução de sistemas primários e de reserva simultaneamente para validar a funcionalidade e o desempenho dos sistemas de reserva sem interromper as operações normais.
tethering	Usar o plano de dados de celular de um dispositivo móvel para fornecer acesso à internet para um laptop ou PC. O PC pode ser conectado ao dispositivo móvel por USB, Bluetooth ou Wi-Fi (um hotspot móvel).
texto cifrado	Dados que foram cifrados e não podem ser lidos sem a chave de cifra.
Texto simples	Dados não criptografados que devem ser criptografados antes de serem transmitidos ou o resultado da descryptografia de dados criptografados.
TI sombra	Hardware, software ou serviços de computador usados em uma rede privada sem autorização do proprietário do sistema.
titular dos dados	Um indivíduo identificado por dados de privacidade.
TLS implícito (FTPS)	Um tipo de FTP que usa TLS para confidencialidade.

token de autenticação físico	Token de autenticação gerado por um criptoprocessador em um dispositivo de hardware dedicado. Como o token nunca é transmitido diretamente, isso cria um fator de propriedade dentro de um esquema de autenticação multifator.
token de autenticação por software	OTP enviada para um número registrado ou conta de e-mail ou gerada por um aplicativo autenticador como um meio de verificação em duas etapas ao validar o acesso à conta.
tokenização	Um método de desidentificação no qual um token exclusivo é substituído por dados reais.
tolerância a falhas	Proteção contra falhas do sistema por meio do fornecimento de capacidade extra (redundante). Geralmente, os sistemas tolerantes a falhas identificam e eliminam pontos únicos de falha. A tolerância a falhas também é conhecida como "redundância".
tolerância ao risco	Determina os limites que separam diferentes níveis de risco.
Traga seu próprio aparelho	Ferramentas e frameworks de segurança para facilitar o uso de dispositivos de propriedade pessoal para acessar redes e dados corporativos.
transferência de estado representacional	Estilo de arquitetura padronizado e sem estado usado por aplicativos Web para fins de comunicação e integração.
transferência de riscos.	Na mitigação de riscos, a resposta de mover ou compartilhar a responsabilidade do risco com outra entidade, como a compra de seguro de cibersegurança.
Transport Layer Security (TLS) (segurança da camada de transporte)	Um protocolo de segurança que usa certificados para autenticação e criptografia que fornece segurança de ponta a ponta para proteger as comunicações na Web e outros protocolos de aplicativos.
Transport Layer Security rede privada virtual	Solução de rede privada virtual que usa certificados digitais para identificar, hospedar e estabelecer túneis seguros para o tráfego de rede.
travas de cabo	Os dispositivos podem ser fisicamente protegidos contra roubo usando abraçadeiras de nylon e cadeados. Alguns sistemas também apresentam placas frontais traváveis, impedindo o acesso ao interruptor de alimentação e a unidades removíveis.
travessia de diretório	Um ataque a aplicativos que permite acesso a comandos, arquivos e diretórios que podem ou não estar conectados ao diretório raiz do documento da Web.
treinamento baseado em computador	Programas de formação e ensino ministrados usando dispositivos de computador e modelos e design instrucional de e-learning.
Tríade CIA	Três princípios de controle e gestão de segurança. Também conhecida como tríade de segurança da informação. Na ordem inversa, pode ser mencionada como a tríade AIC.

troca de chave	Qualquer método pelo qual as chaves criptográficas são transferidas entre os usuários, permitindo assim o uso de um algoritmo criptográfico.
Trojan	Programa de software mal-intencionado escondido dentro de um software aparentemente inócuo. Normalmente, o cavalo de Troia é usado para tentar comprometer a segurança do computador de destino.
tudo como um serviço	Conceito segundo o qual a maioria dos tipos de requisito de TI pode ser implantada como um modelo de serviço de nuvem.
túnel	A prática de encapsular dados de um protocolo para transferência segura através de outra rede, como a Internet.
typosquatting	Um ataque em que um invasor registra um nome de domínio com um erro de ortografia comum de um domínio existente, de modo que um usuário que digite incorretamente uma URL no navegador seja levado ao site do invasor.

U

Um sistema de prevenção de intrusão	Software ou dispositivo de segurança que combina recursos de detecção com funções que podem bloquear ativamente os ataques.
unidade com autocriptografia	Uma unidade de disco na qual o controlador pode criptografar automaticamente os dados gravados nela.
unidade de distribuição de energia	Régua de tomadas avançada ou filtro de linha que fornece tensão de saída filtrada. Uma unidade gerenciada permite a administração remota.
uniform resource locator	Esquema de endereçamento no âmbito de aplicativos para TCP/IP, permitindo o endereçamento de recursos legíveis por humanos. Por exemplo: protocolo://servidor/arquivo, onde "protocolo" representa o tipo de recurso (HTTP, FTP), "servidor" é o nome do computador(www.microsoft.com (http://www.microsoft.com))e "arquivo" é o nome do recurso que você deseja acessar.
Uso de sessão simultânea	Possível indício de atividades mal-intencionadas quando uma conta iniciou múltiplas sessões em um ou mais hosts.

V

variáveis relativas ao ambiente	Na avaliação de vulnerabilidades, trata-se de fatores ou métricas resultantes da configuração da rede local ou host que aumentam ou diminuem a probabilidade básica e influem no grau de risco.
varredura credenciada	Varredura que usa credenciais, como nomes de usuário e senhas, para se aprofundar durante a verificação de vulnerabilidades, o que produzirá mais informações ao passo que se faz a auditoria da rede.
Varredura de vulnerabilidades de aplicativos	Ferramenta de teste de vulnerabilidade projetada para identificar problemas com o código do aplicativo e a configuração da plataforma, incluindo servidores Web e aplicativos Web.

varredura não credenciada	Uma varredura que usa menos permissões e muitas vezes só pode encontrar patches ou atualizações ausentes.
vetor de ameaça	Caminho específico pelo qual um autor de ameaças obtém acesso não autorizado a um sistema.
videovigilância	Controle de segurança física que usa câmeras e dispositivos de gravação para monitorar visualmente a atividade em uma determinada área.
violação de dados	Quando dados confidenciais ou privados são lidos, copiados ou alterados sem autorização. Os eventos de violação de dados podem ter requisitos de notificação e relatório.
virtualização de aplicativo	Um modelo de entrega de software em que o código é executado em um servidor e transmitido a um cliente.
virtualização de funções de rede	Provisionamento de dispositivos de rede virtual, como switches, roteadores e firewalls, via VMs e contêineres.
virtualization (virtualização)	Um ambiente de computação em que vários sistemas operacionais independentes podem ser instalados em uma única plataforma de hardware e executados simultaneamente.
virus (vírus)	Código malicioso inserido em uma image (imagem) de arquivo executável. O código mal-intencionado é executado quando o arquivo é executado e pode fornecer uma área de dados do pacote, como tentar infectar outros arquivos.
vishing	Ataque de engenharia social em que o ator de ameaça extrai informações durante uma conversa telefônica ou utilizando serviços de mensagem de voz baseados em IP (VoIP).
visualização	Um widget que mostra registros ou métricas em um formato visual, como um gráfico ou tabela.
Visualizador de eventos	Console do Windows relacionado à exibição e exportação de eventos no formato de arquivo de log do Windows.
VPN HTML5	Uso de recursos de HTML5 para implementar conexões remotas de área de trabalho/VPN por meio de software de navegador (sem cliente). Também chamado de VPN sem cliente.
vulnerabilidade (vulnerabilidade)	Um ponto fraco que pode ser desencadeado acidentalmente ou explorado de maneira intencional para causar uma violação de segurança.
Vulnerabilidades e exposições comuns	Esquema de identificação de vulnerabilidades desenvolvido pela MITRE e adotado pelo NIST.

W

WAN	Serviços que usam mecanismos definidos por software e políticas de definida por roteamento para implementar túneis virtuais e redes sobrepostas em vários software tipos de rede de transporte.
worm	Tipo de malware que se replica entre os processos na memória do sistema e pode se espalhar pelas conexões de rede cliente/servidor.

Z

zonas de segurança Uma área da rede (ou de uma rede conectada) em que a configuração de segurança é igual para todos os hosts dentro dela. Em segurança física, uma área separada por barreiras que controlam pontos de entrada e saída.

Jurídico (<https://www.comptia.org/legal>) Copyright © CompTIA, Inc. All rights reserved.